



*RiskQuant Product Demonstration Series*

## Scenario 2: Disruptive Threats in Mid-Market Operations

*Vendor supply-chain attacks and the cascading financial effects of SaaS platform failures.*

*Bryon Mascher*

*December, 2025*

*[linkedin.com/in/bryonmascher/cybersec](https://www.linkedin.com/in/bryonmascher/cybersec)*

*[github.com/DigiFenix777](https://github.com/DigiFenix777)*

*This demonstration is part of the RiskQuant Product Demonstration Series — a set of real-world use cases that illustrate how Monte Carlo simulation and intuitive visualization can transform qualitative cybersecurity risk assessments into quantitative, financially actionable insights.*

**RiskQuant v1.0 — Developed by Bryon Mascher · © 2025 All Rights Reserved ·**  
*[linkedin.com/in/bryonmascher/cybersec](https://www.linkedin.com/in/bryonmascher/cybersec) · [github.com/DigiFenix777](https://github.com/DigiFenix777)*

## Table of Contents

|                                                                                                         |           |
|---------------------------------------------------------------------------------------------------------|-----------|
| <b>EXECUTIVE SUMMARY .....</b>                                                                          | <b>7</b>  |
| <b>ES.1 MID-MARKET CYBER RISK &amp; VENDOR RESILIENCE .....</b>                                         | <b>7</b>  |
| <b>ES.2 HYBRID SCENARIO ANALYSIS: VENDOR SUPPLY-CHAIN COMPROMISE .....</b>                              | <b>7</b>  |
| <b>ES.3 WHAT THE COMPARATIVE ANALYSIS REVEALS .....</b>                                                 | <b>8</b>  |
| <b>1. INTRODUCTION AND SCENARIO .....</b>                                                               | <b>10</b> |
| <b>1.1 THREAT LANDSCAPE: VENDOR SUPPLY-CHAIN COMPROMISE IN MID-MARKET ORGANIZATIONS .....</b>           | <b>10</b> |
| <b>1.2 BUSINESS PROBLEM: QUANTIFYING CYBER RISK IN MID-MARKET ENVIRONMENTS.....</b>                     | <b>11</b> |
| 1.2.1 EXECUTIVE PERSPECTIVE — FINANCIAL EXPOSURE & BUSINESS CONTINUITY .....                            | 11        |
| 1.2.2 CYBERSECURITY & IT OPERATIONS PERSPECTIVE — BLIND SPOTS IN VENDOR DEPENDENCIES .....              | 12        |
| 1.2.3 GRC, COMPLIANCE, AUDIT, AND LEGAL PERSPECTIVE — EVIDENCE, DOCUMENTATION, AND ACCOUNTABILITY ..... | 12        |
| 1.2.4 FINANCE, ACCOUNTING, AND ACTUARIAL PERSPECTIVE — UNDERSTANDING VOLATILITY & RESERVES ...          | 12        |
| 1.2.5 WHY QUANTIFICATION MATTERS FOR MID-MARKET ORGANIZATIONS.....                                      | 13        |
| <b>1.3 WHAT RISKQUANT IS AND HOW IT HELPS THE AUDIENCE .....</b>                                        | <b>13</b> |
| <b>1.4 ASIDE: FOR READERS SEEKING A DEEPER TECHNICAL EXPLANATION .....</b>                              | <b>14</b> |
| <b>2. PRE-RUN SETUP.....</b>                                                                            | <b>15</b> |
| <b>2.1 RISKQUANT SETUP PANEL OVERVIEW .....</b>                                                         | <b>15</b> |
| 2.1.1 ANNOTATION 1: INPUT DATA GROUP .....                                                              | 16        |
| 2.1.2 ANNOTATION 2: QUANTIFY RISK GROUP (RUN SIMULATION & RESET) .....                                  | 16        |
| <b>2.2 ABRIDGED DASHBOARD OVERVIEW (MID-MARKET CONTEXT) .....</b>                                       | <b>16</b> |
| 2.2.1 ANNOTATION 1: DATA AND FILTERS.....                                                               | 17        |
| 2.2.2 ANNOTATION 2: KRIS .....                                                                          | 18        |
| 2.2.3 ANNOTATION 3: PORTFOLIO ANNUAL LOSS DISTRIBUTION .....                                            | 18        |
| 2.2.4 ANNOTATION 4: DATA INSIGHTS PANEL .....                                                           | 18        |
| 2.2.5 ANNOTATION 5: SETUP PANEL TOGGLE.....                                                             | 18        |
| <b>2.3 PORTFOLIO ANNUAL LOSS DISTRIBUTION — DATA INSIGHTS PANEL .....</b>                               | <b>18</b> |
| 2.3.1 ANNOTATION 1: PORTFOLIO ANNUAL LOSS DISTRIBUTION — DATA INSIGHTS PANEL .....                      | 19        |
| <b>3. EXPLORING THE MID-MARKET PORTFOLIO: FILTERING AND CONTEXT .....</b>                               | <b>21</b> |
| <b>3.1 INPUT DATA AND KEY RISK INDICATORS (KRIS) - FULL PORTFOLIO .....</b>                             | <b>21</b> |
| 3.1.1 ANNOTATION 1: EXPLORE RISK REGISTER DATA .....                                                    | 22        |
| 3.1.2 ANNOTATION 2: EAL (MEAN): \$4,307,681 .....                                                       | 22        |
| 3.1.3 ANNOTATION 3: MEDIAN: \$4,146,459.....                                                            | 22        |
| 3.1.4 ANNOTATION 4: P95 LOSS: \$7,204,469 .....                                                         | 22        |
| 3.1.5 ANNOTATION 5: MAX OBSERVED: \$13,739,851 .....                                                    | 23        |

|                                                                                  |           |
|----------------------------------------------------------------------------------|-----------|
| <b>3.2 EXPLORE RISK REGISTER DATA (FULL PORTFOLIO VIEW)</b>                      | <b>23</b> |
| 3.2.1 ANNOTATION 1: FULL RISK REGISTER TABLE                                     | 24        |
| <b>3.3 DOMAIN FILTER OVERVIEW</b>                                                | <b>25</b> |
| 3.3.1 ANNOTATION 1: PIVOTING BETWEEN DOMAINS                                     | 26        |
| <b>4. DOMAIN COMPARISON</b>                                                      | <b>27</b> |
| <b>4.1 COMPLIANCE DOMAIN (CMP) — VENDOR-DRIVEN FINANCIAL EXPOSURE</b>            | <b>27</b> |
| 4.1.1 ANNOTATION 1: DOMAIN AND SCENARIOS (CMP SELECTED)                          | 28        |
| 4.1.2 ANNOTATION 2: EXPLORE RISK REGISTER & KRIS                                 | 28        |
| 4.1.3 ANNOTATION 3: PORTFOLIO ANNUAL LOSS DISTRIBUTION (CMP ONLY)                | 29        |
| <b>4.2 CMP DOMAIN – EXPLORE RISK REGISTER DATA (CMP-01 → CMP-03)</b>             | <b>29</b> |
| 4.2.1 ANNOTATION 1: INTERPRETATION                                               | 30        |
| AUDIENCE-FOCUSED INSIGHTS                                                        | 31        |
| SCENARIO CONTEXT TIE-IN                                                          | 31        |
| <b>4.3 GOVERNANCE DOMAIN (GOV) — EXPLORE RISK REGISTER DATA</b>                  | <b>32</b> |
| 4.3.1 ANNOTATION 1: INTERPRETATION                                               | 33        |
| AUDIENCE-FOCUSED INSIGHTS                                                        | 33        |
| SCENARIO CONTEXT TIE-IN                                                          | 34        |
| <b>4.4 GOVERNANCE DOMAIN (GOV) — KRIS AND PORTFOLIO ANNUAL LOSS DISTRIBUTION</b> | <b>34</b> |
| 4.4.1 ANNOTATION 1: DOMAIN AND SCENARIOS (GOV SELECTED)                          | 35        |
| 4.4.2 ANNOTATION 2: KRIS (GOV-ONLY)                                              | 35        |
| 4.4.3 ANNOTATION 3: PORTFOLIO ANNUAL LOSS DISTRIBUTION (GOV ONLY)                | 36        |
| <b>4.5 CMP vs GOV — AUDIENCE TAKE AWAYS</b>                                      | <b>36</b> |
| 1. CMP RISKS PRODUCE HIGHER AND MORE PREDICTABLE ANNUAL LOSS                     | 36        |
| 2. GOV RISKS ARE LOWER-FREQUENCY BUT AMPLIFY SEVERITY WHEN THEY OCCUR            | 37        |
| 3. DOMAIN INTERACTIONS MATTER MORE THAN DOMAIN SILOS                             | 37        |
| 4. DECISION-MAKING IMPLICATIONS FOR MID-MARKET TEAMS                             | 37        |
| 5. SETTING UP THE DEEP DIVE                                                      | 37        |
| <b>5: HYBRID SCENARIO ANALYSIS — MID-MARKET VENDOR SUPPLY-CHAIN COMPROMISE</b>   | <b>39</b> |
| <b>5.1 MODELING HYBRID, CROSS-DOMAIN RISK IN RISKQUANT</b>                       | <b>39</b> |
| 5.1.1 ANNOTATION 1: DASHBOARD CONFIGURATION (HYBRID SCENARIO VIEW)               | 40        |
| 5.1.2 ANNOTATION 2: KRIS (HYBRID SCENARIO SIMULATION)                            | 41        |
| KEY AUDIENCE TAKEAWAYS:                                                          | 41        |
| 5.1.3 ANNOTATION 3: PORTFOLIO ANNUAL LOSS DISTRIBUTION (HYBRID VIEW)             | 41        |
| <b>5.2 INLINE RISK REGISTER EXPOSURE — AUDIENCE VALUE AND DECISION SUPPORT</b>   | <b>42</b> |
| 5.2.1 ANNOTATION 1: QUALITATIVE ASSESSMENTS (LIKELIHOOD, IMPACT, RATING)         | 43        |
| WHY THIS MATTERS FOR THE AUDIENCE                                                | 43        |
| FROM QUALITATIVE TO QUANTITATIVE — HOW MONTE CARLO ENABLES DECISION-MAKING       | 43        |
| <b>5.3 INTERPRETING HYBRID SCENARIO KRIS — EVIDENCE-SUPPORTED INSIGHTS</b>       | <b>44</b> |
| INTERPRETATION                                                                   | 45        |
| ANNOTATION 1: EAL (MEAN) — \$1,574,962                                           | 45        |
| ANNOTATION 3: P95 LOSS — \$2,957,574                                             | 45        |

|                                                                                  |               |
|----------------------------------------------------------------------------------|---------------|
| ANNOTATION 4: MAX OBSERVED — \$5,574,397.....                                    | 46            |
| ANNOTATION 5: PORTFOLIO ANNUAL LOSS DISTRIBUTION (HYBRID).....                   | 46            |
| AUDIENCE-FOCUSED INSIGHTS.....                                                   | 46            |
| SCENARIO CONTEXT TIE-IN .....                                                    | 47            |
| <b>5.4 DISTRIBUTION BY SCENARIO (BAR GRAPH) — SCENARIO-LEVEL EXPOSURE .....</b>  | <b>47</b>     |
| 5.4.1 ANNOTATION 1: WHY THE DISTRIBUTION BY SCENARIO VISUALIZATION MATTERS ..... | 48            |
| 5.4.2 ANNOTATION 2: CMP-02 — ~\$1.75M (P95) .....                                | 48            |
| 5.4.3 ANNOTATION 3: CMP-03 — ~\$1.1M (P95) .....                                 | 49            |
| 5.4.4 ANNOTATION 4: GOV-01 — ~\$1.1M (P95) .....                                 | 49            |
| 5.4.5 ANNOTATION 5: SEC-03 — ~\$0.55M (P95) .....                                | 49            |
| AUDIENCE-FOCUSED INSIGHTS.....                                                   | 49            |
| SCENARIO CONTEXT TIE-IN .....                                                    | 50            |
| <br><b>6: SCENARIO DEEP DIVE — CMP-03 VS SEC-03 VENDOR EXPOSURE .....</b>        | <br><b>51</b> |
| <br><b>6.1 CMP-03 SCENARIO ANALYSIS — SAAS CRM VENDOR BREACH .....</b>           | <br><b>51</b> |
| 6.1.1 DOMAIN & SCENARIO CONFIRMATION (CMP-03 SELECTED).....                      | 52            |
| 6.1.2 KRIS — UNDERSTANDING CMP-03 FINANCIAL EXPOSURE .....                       | 52            |
| AUDIENCE TAKEAWAYS .....                                                         | 53            |
| 6.1.3 PORTFOLIO ANNUAL LOSS DISTRIBUTION — CMP-03 .....                          | 53            |
| AUDIENCE TAKEAWAYS .....                                                         | 54            |
| <b>6.2 CMP-03 — CUMULATIVE PROBABILITY (CDF) .....</b>                           | <b>54</b>     |
| 6.2.1 ANNOTATION 1: CMP-03 CDF CURVE.....                                        | 55            |
| AUDIENCE-FOCUSED INSIGHTS.....                                                   | 56            |
| SCENARIO CONTEXT TIE-IN .....                                                    | 56            |
| <b>6.3 CMP-03 — DISTRIBUTION BY SCENARIO (BOX &amp; VIOLIN COMPARISON).....</b>  | <b>56</b>     |
| 6.3.1 ANNOTATION 1: CMP-03 DISTRIBUTION VISUALIZATION (BOX MODE) .....           | 57            |
| 6.3.2 ANNOTATION 2: COMPARISON TYPE = BOX.....                                   | 57            |
| 6.3.3 ANNOTATION 3: GENERATE PER-SCENARIO SAMPLES (ENABLED) .....                | 57            |
| 6.3.4 ANNOTATION 4: SAMPLES PER SCENARIO = 5,000 .....                           | 58            |
| 6.3.5 ANNOTATION 5: CMP-03 BOX PLOT INTERPRETATION .....                         | 58            |
| AUDIENCE-FOCUSED INSIGHTS.....                                                   | 58            |
| SCENARIO CONTEXT TIE-IN .....                                                    | 59            |
| <b>6.4 CMP-03 — VIOLIN PLOT INTERPRETATION (15,000 SAMPLES).....</b>             | <b>59</b>     |
| 6.4.1 ANNOTATION 1: VIOLIN VISUALIZATION (CMP-03).....                           | 60            |
| 6.4.2 ANNOTATION 2: “VIOLIN” COMPARISON TYPE SELECTED.....                       | 60            |
| 6.4.3 ANNOTATION 3: SAMPLES PER SCENARIO = 15,000 .....                          | 60            |
| 6.4.4 ANNOTATION 4: VIOLIN PLOT INTERPRETATION (CMP-03) .....                    | 60            |
| AUDIENCE-FOCUSED INSIGHTS.....                                                   | 61            |
| SCENARIO CONTEXT TIE-IN .....                                                    | 61            |
| <b>6.5 CMP-03 — RISK MATRIX (QUALITATIVE VS. QUANTITATIVE ALIGNMENT) .....</b>   | <b>61</b>     |
| 6.5.1 ANNOTATION 1: QUALITATIVE INPUTS + QUANTITATIVE OUTPUTS .....              | 62            |
| WHY THIS MATTERS TO THE AUDIENCE .....                                           | 63            |

|                                                                                                                    |           |
|--------------------------------------------------------------------------------------------------------------------|-----------|
| <b>7: CMP-03 VS. SEC-03 COMPARATIVE ANALYSIS — VENDOR DATA EXPOSURE VS. VENDOR CREDENTIAL/API COMPROMISE .....</b> | <b>64</b> |
| <b>7.1 SCENARIO &amp; KRI COMPARISON — CMP-03 vs SEC-03 .....</b>                                                  | <b>64</b> |
| 7.1.1 ANNOTATION 1: SCENARIO FILTERS (CMP-03 vs SEC-03).....                                                       | 66        |
| 7.1.2 ANNOTATION 2: KRI COMPARISON TABLE .....                                                                     | 66        |
| AUDIENCE-FOCUSED INSIGHTS.....                                                                                     | 67        |
| 7.1.3 PORTFOLIO ANNUAL LOSS DISTRIBUTION — CMP-03 vs SEC-03 .....                                                  | 67        |
| AUDIENCE-FOCUSED INSIGHTS.....                                                                                     | 68        |
| SCENARIO CONTEXT TIE-IN .....                                                                                      | 68        |
| <b>7.2 CUMULATIVE PROBABILITY (CDF) — CMP-03 vs SEC-03 .....</b>                                                   | <b>69</b> |
| 7.2.1 ANNOTATION 1: CMP-03 vs. SEC-03 CDF CURVE ANALYSIS .....                                                     | 70        |
| AUDIENCE-FOCUSED INSIGHTS.....                                                                                     | 71        |
| SCENARIO CONTEXT TIE-IN .....                                                                                      | 71        |
| <b>7.3 DISTRIBUTION BY SCENARIO (BOX COMPARISON) — CMP-03 vs SEC-03.....</b>                                       | <b>71</b> |
| 7.3.1 ANNOTATION 1: ANALYSIS — CMP-03 vs. SEC-03 (BOX MODE) .....                                                  | 73        |
| AUDIENCE-FOCUSED INSIGHTS.....                                                                                     | 73        |
| SCENARIO CONTEXT TIE-IN .....                                                                                      | 74        |
| <b>7.4 DISTRIBUTION BY SCENARIO (VIOLIN COMPARISON) — CMP-03 vs SEC-03 .....</b>                                   | <b>74</b> |
| 7.4.1 ANNOTATION 1: ANALYSIS — CMP-03 vs SEC-03 (VIOLIN MODE) .....                                                | 75        |
| AUDIENCE-FOCUSED INSIGHTS.....                                                                                     | 76        |
| SCENARIO CONTEXT TIE-IN .....                                                                                      | 76        |
| <b>7.5 RISK MATRIX — CMP-03 vs SEC-03 .....</b>                                                                    | <b>77</b> |
| 7.5.1 ANNOTATION 1: QUALITATIVE VS QUANTITATIVE ALIGNMENT — CMP-03 vs SEC-03 .....                                 | 78        |
| AUDIENCE-FOCUSED INSIGHTS.....                                                                                     | 79        |
| SCENARIO CONTEXT TIE-IN .....                                                                                      | 80        |
| <b>8. CONCLUSIONS &amp; SCENARIO TAKEAWAYS .....</b>                                                               | <b>81</b> |
| <b>8.1 CMP-03 KEY TAKEAWAYS — PREDICTABLE, HIGH-IMPACT VENDOR BREACH.....</b>                                      | <b>81</b> |
| <b>8.2 SEC-03 KEY TAKEAWAYS — VOLATILE, LOW-FREQUENCY BUT SEVERE EXPOSURE .....</b>                                | <b>81</b> |
| <b>8.3 WHAT THE COMPARISON REVEALS .....</b>                                                                       | <b>82</b> |
| <b>8.4 RECOMMENDATIONS FOR LEADERSHIP &amp; STAKEHOLDERS .....</b>                                                 | <b>82</b> |
| <b>8.5 HOW RISKQUANT ENABLES BETTER DECISIONS .....</b>                                                            | <b>83</b> |
| <b>8.6 EXPLORE THE COMPLETE RISKQUANT SCENARIO SERIES .....</b>                                                    | <b>83</b> |
| RISKQUANT DEMO SERIES .....                                                                                        | 84        |
| <b>9: EXPORT FUNCTIONALITY &amp; OPERATIONAL VALUE .....</b>                                                       | <b>85</b> |
| <b>9.1 HOW EXPORT FUNCTIONALITY BENEFITS EACH AUDIENCE SEGMENT .....</b>                                           | <b>85</b> |
| 9.1.1 ANNOTATION 1: DOWNLOAD PORTFOLIO SAMPLES (CSV) .....                                                         | 86        |
| 9.1.2 ANNOTATION 2: DOWNLOAD RUN MANIFEST (JSON) .....                                                             | 86        |
| <b>7. AUTHOR’S NOTE .....</b>                                                                                      | <b>88</b> |

|                         |           |
|-------------------------|-----------|
| <b>8. SOURCES .....</b> | <b>90</b> |
|-------------------------|-----------|

# Executive Summary

## ES.1 Mid-Market Cyber Risk & Vendor Resilience

Mid-market organizations—typically employing several hundred to several thousand staff—face a disproportionate level of cyber risk relative to their resources and internal security maturity. As these organizations scale, they increasingly rely on **SaaS platforms, cloud-hosted analytics, external development partners, and managed service providers**, often without the necessary governance, oversight, or in-house expertise to effectively manage the resulting risks.

Public data confirms this exposure. Industry reporting shows that **approximately 41% of breaches involve third-party or partner environments**, reflecting the growing role of vendor ecosystems in modern attack paths [1]. Mid-market organizations are particularly vulnerable, as attackers recognize that these firms often hold high-value data while lacking the robust security controls of large enterprises.

The financial consequences are material. According to IBM's Cost of a Data Breach Report, the average cost of a supply-chain-related breach increased again in 2024, reaching approximately \$4.76 million, significantly exceeding the cost of internally originated incidents [2]. These breaches frequently involve personally identifiable information (PII)—the most commonly exposed data type—resulting in elevated legal, regulatory, and contractual impacts under frameworks such as GLBA and PCI DSS [1][2]. ENISA further highlights the rise of multi-vector attacks exploiting cloud services, APIs, and third-party integrations as a defining trend in recent threat landscapes [4].

Together, these conditions create a risk multiplier for mid-market organizations: vendor ecosystems expand faster than internal security programs, governance processes lag SaaS adoption, and data-protection controls often fail to align with how third parties process or store sensitive information.

## ES.2 Hybrid Scenario Analysis: Vendor Supply-Chain Compromise

This demonstration uses **RiskQuant**, a Monte Carlo-based cyber risk quantification platform, to examine how these dynamics interact across domains—and how their **combined financial impact** emerges when modeled quantitatively.

Rather than treating cyber risk as a single failure, the analysis introduces a **hybrid scenario framework** that reflects how real-world incidents typically unfold through cascading governance, compliance, and security breakdowns. From this foundation, the demo explores and compares two high-impact vendor-origin scenarios:

- **CMP-03: SaaS CRM Vendor Breach**, representing regulated customer data exposure driven by compliance and data-handling failures.
- **SEC-03: Third-Party API Key or Credential Compromise**, representing identity-driven escalation through vendor integrations and cloud services.

• RiskQuant applies Monte Carlo simulation to generate thousands of plausible outcomes for each scenario, translating qualitative risk register inputs—aligned with **NIST SP 800-53**, **NIST RMF (SP 800-37)**, and **ISO/IEC 27005**—into statistically defensible financial distributions [5][6][7].

## ES.3 What the Comparative Analysis Reveals

Although CMP-03 and SEC-03 are both rated “High” risk qualitatively, their **quantitative behavior differs significantly**:

- **CMP-03** exhibits **predictable, recurring annual losses**, driven by regulated PII exposure and compliance obligations. Losses are financially material every year, stable across quartiles, and well-suited to long-term budgeting and control ROI analysis.
- **SEC-03** exhibits **low-frequency but high-severity behavior**, with many years of zero losses interrupted by sharp, multi-million-dollar tail events when attackers abuse credentials or APIs. This volatility complicates forecasting and elevates the importance of resilience planning and insurance strategy.

External research aligns closely with these modeled outcomes:

- Vendor and supply-chain compromises account for **~41% of breaches** [1].
- **Credential misuse and API abuse** continue to rise as dominant attack vectors [1][4].
- **SaaS and CRM-related PII exposures** routinely exceed **\$1M** in cost for mid-market organizations [2][3].
- Supply-chain incidents remain **13–20% more expensive** than internally originated breaches [2].

This alignment validates both the **realism of the scenarios** and the **value of quantitative modeling** as a decision-support tool.

Why This Matters for Mid-Market Leaders

The analysis demonstrates that mid-market organizations do not face a single category of vendor risk, but **two distinct and complementary exposures**:

- **Steady-state, compliance-driven losses** that require recurring investment, governance discipline, and vendor assurance.
- **Volatile, identity-driven tail risk** that demands resilience planning, contingency funding, and insurance alignment.



By converting qualitative risk assessments into **measurable financial outcomes**, RiskQuant enables business leaders, IT teams, GRC stakeholders, and finance leaders to:

- Prioritize controls based on evidence rather than intuition
- Align security and compliance investments with **actual loss behavior**
- Communicate cyber risk credibly to executives, boards, and insurers
- Make defensible decisions about vendors, contracts, and integrations

Ultimately, this mid-market demonstration shows that **two risks labeled “High” are not equal**—and that understanding the difference is critical as organizations scale. RiskQuant bridges the gap between frameworks and financial reality, providing the clarity needed to manage vendor-driven cyber risk in an increasingly interconnected business environment.

# 1. Introduction and Scenario

Mid-market organizations—typically ranging from several hundred to several thousand employees—find themselves at a challenging crossroads in the modern cybersecurity landscape. Mid-market organizations manage complex infrastructures, rely heavily on third-party SaaS platforms, and must comply with regulatory obligations that often exceed their available security resources. For these organizations, understanding the origin of cyber risk and its financial impact on the business is essential for effective planning, budgeting, and strategic decision-making.

**RiskQuant** addresses this challenge by transforming qualitative risk assessments into *quantified loss expectations* through the use of Monte Carlo simulation. For mid-market teams—including cybersecurity operations, compliance, leadership, finance, and audit—RiskQuant provides a repeatable, evidence-based approach to understanding exposure, prioritizing controls, and demonstrating ROI on security investments. This scenario focuses on one of the most consequential risks facing mid-market companies today:

## **Vendor supply-chain compromise leading to business disruption.**

As organizations expand their digital ecosystems to include SaaS CRMs, cloud-hosted analytics, payment platforms, and external development partners, the attack surface grows in ways that traditional risk scoring cannot fully capture. This demonstration illustrates how a vendor-driven, explicitly modeled approach in the CMP-03 SaaS CRM breach scenario produces volatile and high-severity outcomes that mid-market leadership must understand and prepare for.

## 1.1 Threat Landscape: Vendor Supply-Chain Compromise in Mid-Market Organizations

Supply-chain attacks targeting mid-market organizations have increased sharply in recent years, driven by attackers exploiting trusted vendors, misconfigured integrations, and exposed credentials within the software supply chain. Mid-market companies are particularly vulnerable because they rely on numerous external platforms—such as billing, CRM, analytics, payment APIs, cloud IAM, and managed service providers—while often lacking a comprehensive enterprise-level security stack to detect, isolate, or contain upstream compromises.

Industry research reinforces this concern:

- Forbes reports that **ransomware and supply-chain attacks are among the fastest-growing threats impacting mid-market firms**, which have valuable assets but fewer layers of defense compared to large enterprises [1].
- Techaisle's 2024 mid-market security report notes that **organizations in this tier increasingly rely on interconnected SaaS ecosystems**, where a single vendor weakness can propagate into core business processes, triggering downtime, data exposure, or compliance failures [3].

In this environment, even a single vendor breach—such as a CRM provider’s compromise exposing GLBA-regulated customer data—can disrupt operations, erode customer trust, and lead to downstream regulatory and financial consequences.

This scenario illustrates how RiskQuant enables mid-market organizations to model vendor-driven disruptions and comprehend their actual financial impact.

## 1.2 Business Problem: Quantifying Cyber Risk in Mid-Market Environments

Mid-market organizations face a systemic challenge: they must manage a complex risk surface while justifying security decisions to leaders, auditors, boards, and regulators—often with limited staff and budget. Organizations treat vendor risk management as a top priority, yet qualitative scoring (High, Medium, Low) fails to answer a foundational question:

**"How much financial exposure does this vendor dependency create for our business?"**

RiskQuant addresses this gap by:

- Converting qualitative ratings into annual loss projections
- Modeling the volatility and uncertainty inherent in vendor risk
- Providing percentiles (p50, p95, p99) that support budgeting and insurance decisions
- Creating audit-ready artifacts (CSV/JSON) for traceability
- Empowering leaders to compare internal vs external risks objectively

The Mid-Market scenario reveals how vendor-originated compromise (CMP-03) produces a unique loss pattern:

- **Many years with no losses**
- **Some years with moderate losses (~\$300K)**
- **Rare but severe outcomes exceeding \$1M–\$2M**

Mirroring real-world CRM SaaS breach dynamics [2]. These are the insights mid-market leadership and cybersecurity teams urgently need.

### 1.2.1 Executive Perspective — Financial Exposure & Business Continuity

Executives in mid-market organizations operate under intense pressure to balance operational continuity, regulatory obligations, and strategic growth. Yet most lack visibility into the *financial magnitude* of a vendor breach. A compromise at a CRM, analytics platform, or payment processor can:

- Interrupt revenue operations
- Expose regulated customer data (GLBA)
- Trigger breach notifications and fines
- Damage customer relationships
- Increase insurance premiums

- Require costly remediation and legal response

Executives need **quantified** risk to justify investments in redundancy, vendor governance, and incident response planning. RiskQuant provides this visibility by expressing risk in financial terms that align with budgeting, resilience planning, and board communication.

### 1.2.2 Cybersecurity & IT Operations Perspective — Blind Spots in Vendor Dependencies

Security engineers, analysts, and managers face a second challenge: vendor compromise often occurs *outside* their control, and traditional tools rarely capture the business impact. Vendor-originated breaches, such as SaaS CRM vendor breach exposing customer data (CMP-03) or API Key leakage from contractor repo (SEC-03) can:

- Introduce unauthorized access via misconfigured integrations
- Leak API keys
- Propagate malware or credential theft
- Lead to cascading system failures

RiskQuant enables technical teams to model incident chains, compare vendor vs internal risks, and validate where mitigation efforts (e.g., vendor tiering, SOC 2 reviews, IAM hardening) will yield the greatest return on investment.

### 1.2.3 GRC, Compliance, Audit, and Legal Perspective — Evidence, Documentation, and Accountability

Mid-market GRC and compliance teams must navigate PCI DSS, GLBA, SOC 2, and internal audit requirements—each demanding structured evidence of risk reasoning. Vendor breaches often trigger:

- Audit findings
- Regulatory inquiries
- Contractual obligations to notify affected customers or partners

RiskQuant provides exportable simulation results that support:

- Risk treatment documentation
- Vendor assessments
- Audit trails
- Cyber insurance renewals
- Regulatory reporting

This approach transforms subjective discussion into **traceable, defensible evidence**.

### 1.2.4 Finance, Accounting, and Actuarial Perspective — Understanding Volatility & Reserves

Financial stakeholders require predictable models to establish reserves, assess insurance policies, and assess financial exposure. Vendor breaches are notoriously tricky to forecast because:

- Losses vary widely year to year

- Impact depends on vendor criticality
- Regulatory penalties vary by jurisdiction

RiskQuant provides financial teams with impact probabilities (p50, p90, p95, p99) that align with actuarial expectations, enabling more accurate financial planning and decision-making.

### 1.2.5 Why Quantification Matters for Mid-Market Organizations

Unlike small businesses, mid-market organizations face both **enterprise-level regulatory requirements** and **Small Business-Level resource constraints**. Mid-market organizations rely on external vendors in ways that create hidden risk concentrations, which qualitative scoring alone cannot reveal.

RiskQuant enables these organizations to:

- Identify vendor scenarios with the highest tail-risk potential
- Quantify their exposure using a Monte Carlo simulation
- Compare vendor risks against internal operational risks
- Justify governance and compliance investments
- Communicate risk clearly to leadership and boards
- Strengthen cyber insurance negotiations
- Improve business continuity readiness

Vendor supply-chain compromise is one of the most consequential threats facing mid-market organizations—and quantification is essential for understanding and mitigating that risk.

## 1.3 What RiskQuant Is and How It Helps the Audience

RiskQuant is a Python-based cyber risk quantification tool that transforms qualitative assessments—such as likelihood, impact, and regulatory context—into **quantified annual loss expectations** using Monte Carlo simulation. Built for real-world decision-makers, the platform enables mid-market organizations to assess risk drivers in financial terms, compare internal and vendor-originated exposures, and generate defensible outputs for leadership, auditors, and insurers.

In the context of **vendor supply-chain compromise**, RiskQuant gives teams the ability to model how disruptions at external SaaS platforms, payment processors, or analytics vendors translate into operational downtime, financial losses, and regulatory obligations. Simulating thousands of potential outcomes helps teams understand:

- **Typical yearly exposure (median)**
- **Expected Annual Loss (mean)**
- **Severe but realistic scenarios (p95)**
- **Catastrophic tail risks (p99 and Max Observed)**
- **Uncertainty and volatility across years**

These insights are crucial for mid-market organizations navigating complex vendor ecosystems, where failures often occur beyond their direct control.

RiskQuant's dashboard visualizes these results through intuitive charts—the Portfolio Annual Loss Distribution, Cumulative Probability curves, Scenario Distributions, and Risk Matrix—enabling audience members at every level to quickly interpret risk severity and make informed decisions. The platform's built-in export capability (CSV + JSON) supports compliance requirements, board reporting, and cyber insurance analysis with complete transparency and reproducibility.

For mid-market organizations balancing regulatory pressure, operational dependence on vendors, and finite resources, RiskQuant provides a practical, repeatable way to answer critical questions such as:

- *“Which vendor poses the highest financial exposure?”*
- *“How likely is a million-dollar loss?”*
- *“Where should we invest to reduce risk most effectively?”*
- *“How do we communicate vendor risk to leadership and auditors?”*

Whether used by cybersecurity teams evaluating vendor posture, by GRC practitioners preparing for audits, or by executives determining risk tolerance and budget, RiskQuant enables clear, data-driven decisions grounded in statistically sound analysis.

---

## 1.4 Aside: For Readers Seeking a Deeper Technical Explanation

For a deeper look into Monte Carlo simulation, risk register parameterization, and the statistical model underlying RiskQuant—including distributions, lambda mappings, asset valuation tiers, and a complete dashboard walkthrough—refer to the *RiskQuant White Paper: Quantitative Cyber Risk Analysis with Monte Carlo Simulation*.

This demonstration remains intentionally concise and scenario-focused, emphasizing practical value, audience-specific insights, and the real-world impact of supply-chain attacks targeting mid-market organizations.

---

## 2. Pre-Run Setup

Before analyzing the Mid-Market vendor supply-chain compromise scenario, users configure the simulation and load the appropriate risk-register data. RiskQuant reads from the selected risk register, executes a Monte Carlo simulation, and populates the dashboard with quantified loss projections. Rather than repeat the complete configuration workflow covered in the **SMB scenario**, this section highlights only the setup steps relevant to the Mid-Market analysis.

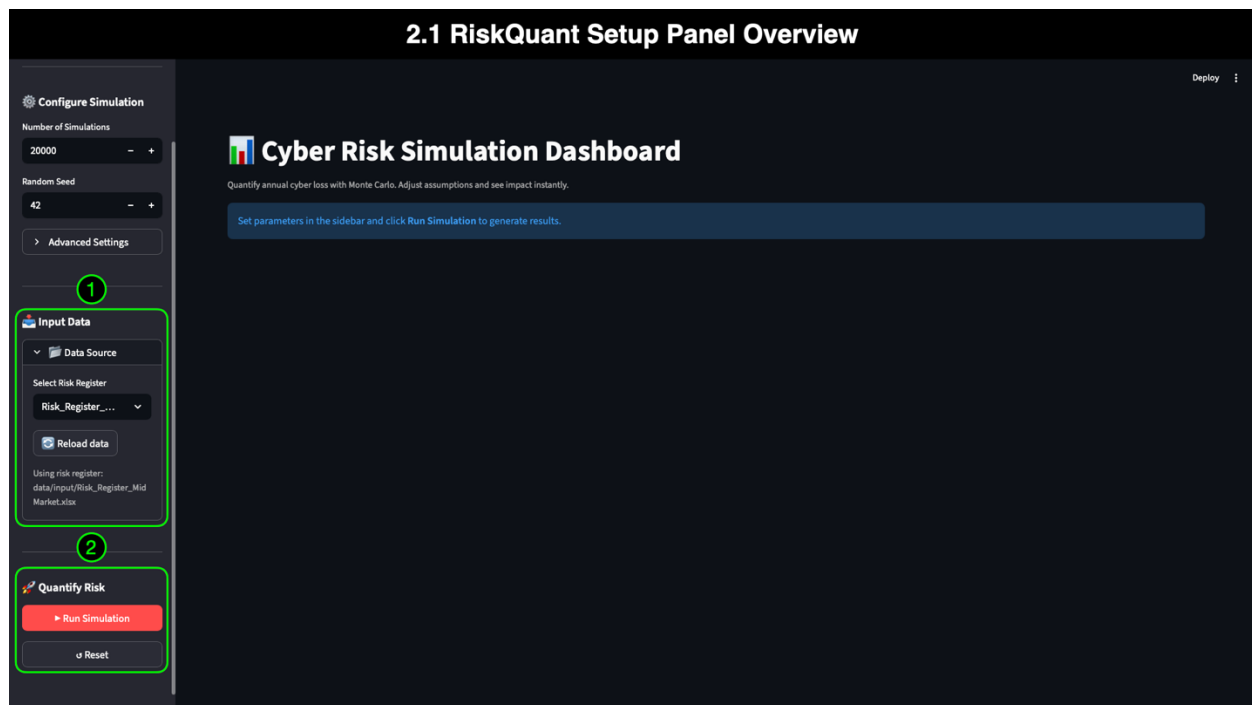
In the Mid-Market demo, we load the **Risk\_Register\_Mid\_Market.xlsx** file, confirm that the expected dataset is active, and run the simulation to generate the KRIs, distributions, and scenario tiles used throughout the analysis. After running the simulation, the demo focuses on filtering, comparing, and exploring scenarios to quantify the impact of vendor compromise.

### 2.1 RiskQuant Setup Panel Overview

The Setup Panel organizes the pre-run configuration into three logical groupings that guide the user from simulation definition to data selection to executing the run:

- **Configure Simulation** — Simulation count, random seed, percentiles, and currency
- **Input Data** — Risk register file selection and data reload control
- **Quantify Risk** — Run Simulation and Reset dashboard actions

These controls ensure the simulation uses the correct parameters, data sources, and reproducible logic before the dashboard is populated.



### 2.1.1 Annotation 1: Input Data Group

This annotation highlights the **Input Data** section, where the Mid-Market risk register is selected. The path shown in the interface confirms that **Risk\_Register\_Mid\_Market.xlsx** is the active dataset. This approach ensures that all KRIs, distributions, and analytics in the demo accurately reflect mid-market vendor-related risks, including the CMP-03 SaaS CRM breach scenario. The **Reload Data** option allows users to refresh the dashboard if a different risk register is selected or if the file is modified and re-saved.

### 2.1.2 Annotation 2: Quantify Risk Group (Run Simulation & Reset)

This annotation identifies the controls used to initiate or clear a simulation:

- **Run Simulation** executes the Monte Carlo model using the loaded risk register and the parameters defined in Configure Simulation. This step populates all KRIs, scenario tiles, and visualizations across the dashboard.
- **Reset** clears the simulation results, removes all filters, and returns the dashboard to its default state.

With the Mid-Market register loaded and the simulation executed, the dashboard is ready for domain filtering, scenario comparison, and deep analysis of vendor supply-chain compromise.

## 2.2 Abridged Dashboard Overview (Mid-Market Context)

With the Mid-Market risk register loaded and the simulation executed, the dashboard provides an immediate, quantitative view of organizational exposure across governance,



compliance, operational, and security domains. Each visual and KRI reflects results from a Monte Carlo simulation, where thousands of iterations estimate the frequency and severity of loss events in a given year.

For a mid-market audience—often working with complex vendor ecosystems, internal dependencies, and regulatory requirements—Monte Carlo modeling provides a structured way to translate qualitative ratings (such as “Medium Likelihood” or “High Impact”) into financial projections that leadership, finance, and audit can act upon. This section provides a brief overview of the dashboard layout, followed by an exploration of domain-specific and scenario-specific insights.



### 2.2.1 Annotation 1: Data and Filters

This group includes the key controls that shape what appears in the dashboard:

- **Domain Filter:** Enables users to isolate Governance (GOV), Compliance (CMP), Operations (OPS), and Security (SEC) risk scenarios for comparing internal versus vendor-originated exposures.
- **Scenarios Filter:** Dynamically updates based on the selected domain, enabling scenario-by-scenario evaluation—critical for isolating the CMP-03 vendor breach scenario.
- **Explore Risk Register Data:** This feature displays the source dataset (*Active data: Risk\_Register\_MidMarket.xlsx*) and enables users to audit qualitative inputs directly within the dashboard.

These controls form the foundation of scenario exploration and domain-level analysis.

### 2.2.2 Annotation 2: KRIs

The KRI row provides four core metrics derived from the simulation:

- **EAL (Mean):** Expected Annual Loss across all simulation years—useful for budgeting and insurance planning.
- **Median:** Represents the “typical” annual loss outcome, indicating central tendency even when many years have zero or low-loss events.
- **p95 Loss:** Illustrates severe but realistic losses in the top 5% of cases—important for executives, risk committees, and regulators evaluating worst-case scenarios.
- **Max Observed:** The highest modeled impact across all iterations, demonstrating the potential upper boundary of catastrophic loss.
- Together, these KRIs translate probability and impact into financial terms that decision-makers can understand.

### 2.2.3 Annotation 3: Portfolio Annual Loss Distribution

The histogram shown here is the first of four key visualizations in RiskQuant. It illustrates the frequency of different loss levels across thousands of simulated years, revealing both common and rare outcomes.

While this Mid-Market demo does not repeat the full dashboard tutorial present in the SMB scenario, users can reference that earlier walkthrough for an in-depth explanation of each visualization type (Distribution, CDF, Scenario Comparison, and Risk Matrix). This demo focuses instead on how those visuals apply to mid-market vendor-related risks.

### 2.2.4 Annotation 4: Data Insights Panel

The **Data Insights** button provides an in-line explanation and context tailored to each visualization. The panel offers definitions, usage tips, and audience-specific guidance, including insights into how executives interpret percentile lines and how GRC teams utilize distribution data in risk reporting. We will explore this panel more deeply in the next section, but its presence ensures self-guided learning for users new to quantitative analysis.

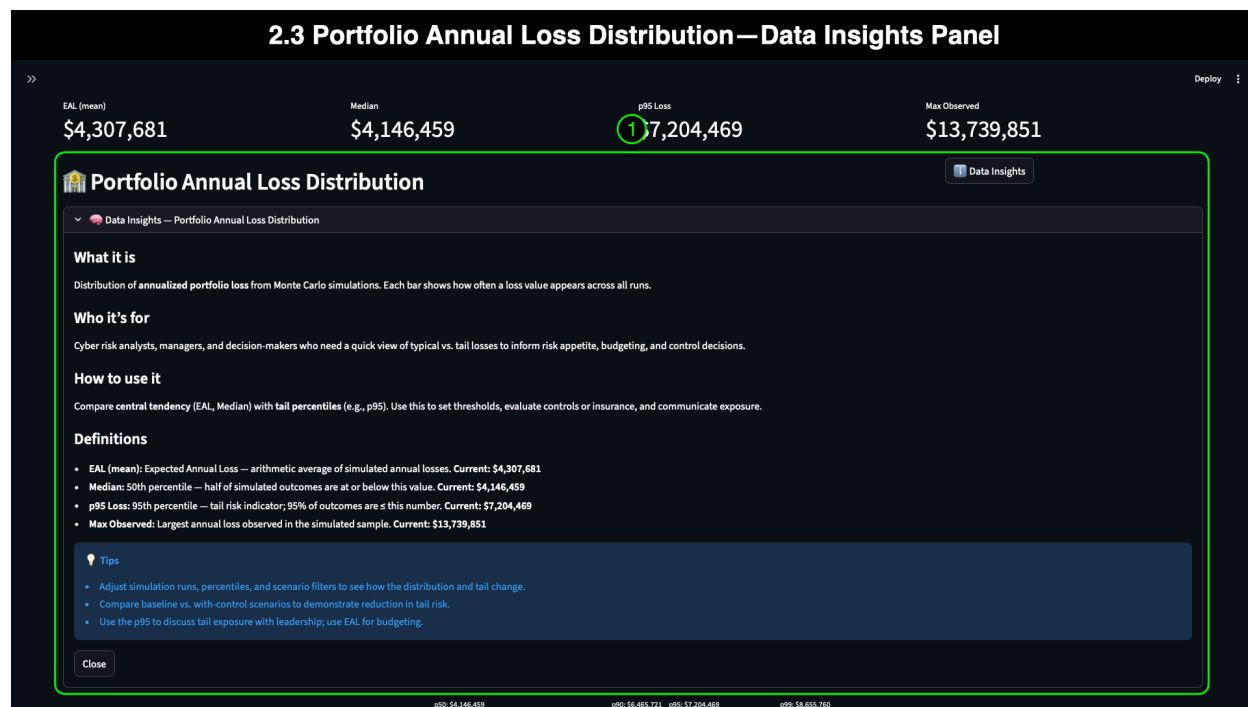
### 2.2.5 Annotation 5: Setup Panel Toggle

The Setup Panel toggle (icon near the top-left) expands or collapses the configuration controls. Collapsing the panel maximizes screen space for visual analysis and provides a cleaner experience once the simulation is complete. In this demo, the Setup Panel remains collapsed for all subsequent screenshots to keep the focus on scenario exploration.

## 2.3 Portfolio Annual Loss Distribution — Data Insights Panel

RiskQuant includes a **Data Insights** panel for every dashboard visualization, accessible through the “Data Insights” button located near each chart. These panels provide concise,

context-aware explanations that help users understand how to interpret the visual elements—especially valuable for stakeholders who may be less familiar with Monte Carlo simulation or statistical terminology. In the Mid-Market scenario, the Data Insights panel ensures that executives, cybersecurity teams, finance, and GRC stakeholders can derive consistent meaning from the Portfolio Annual Loss Distribution without requiring prior quantitative expertise.



### 2.3.1 Annotation 1: Portfolio Annual Loss Distribution — Data Insights Panel

The annotation highlights the full Data Insights panel, which includes the following guidance sections tailored for a broad set of mid-market audiences:

#### *What It Is*

This section explains that the Portfolio Annual Loss Distribution is a histogram derived from thousands of Monte Carlo simulation iterations. For mid-market teams, it clarifies that each bar represents the frequency of a modeled annual loss amount, showing how often typical, moderate, and severe financial impacts occur.

#### *Who It's For*

The panel outlines the audiences that benefit most from this visualization:

- **Executives:** To understand the spread and volatility of potential yearly losses.
- **GRC & Compliance:** To support reporting, risk treatment plans, and regulatory documentation.
- **Cybersecurity & IT Operations:** To evaluate the risk relevance of controls, vendor dependencies, and mitigation strategies.

- **Finance & Audit:** To interpret percentile-based loss values used in budgeting and reserves.

### *How to Use It*

This section provides clear instructions for interpreting the histogram:

- Identify how frequently zero-loss years occur.
- Review the clustering of bars around common loss values (e.g., median).
- Examine percentile markers (p50, p90, p95) to understand typical and severe outcomes.
- Observe the long right tail that represents rare but high-impact vendor-driven loss events—critical in supply chain compromise scenarios.

### *Definitions*

The panel provides short, accessible definitions for key terms such as:

- **Expected Annual Loss (EAL)**
- **Median (p50)**
- **Tail Risk**
- **p95 / p99 Loss**
- **Simulation Iterations**

These definitions help ensure a shared understanding across technical and non-technical stakeholders.

### *Tips*

This guidance helps readers interpret the results without requiring prior experience in quantitative risk analysis:

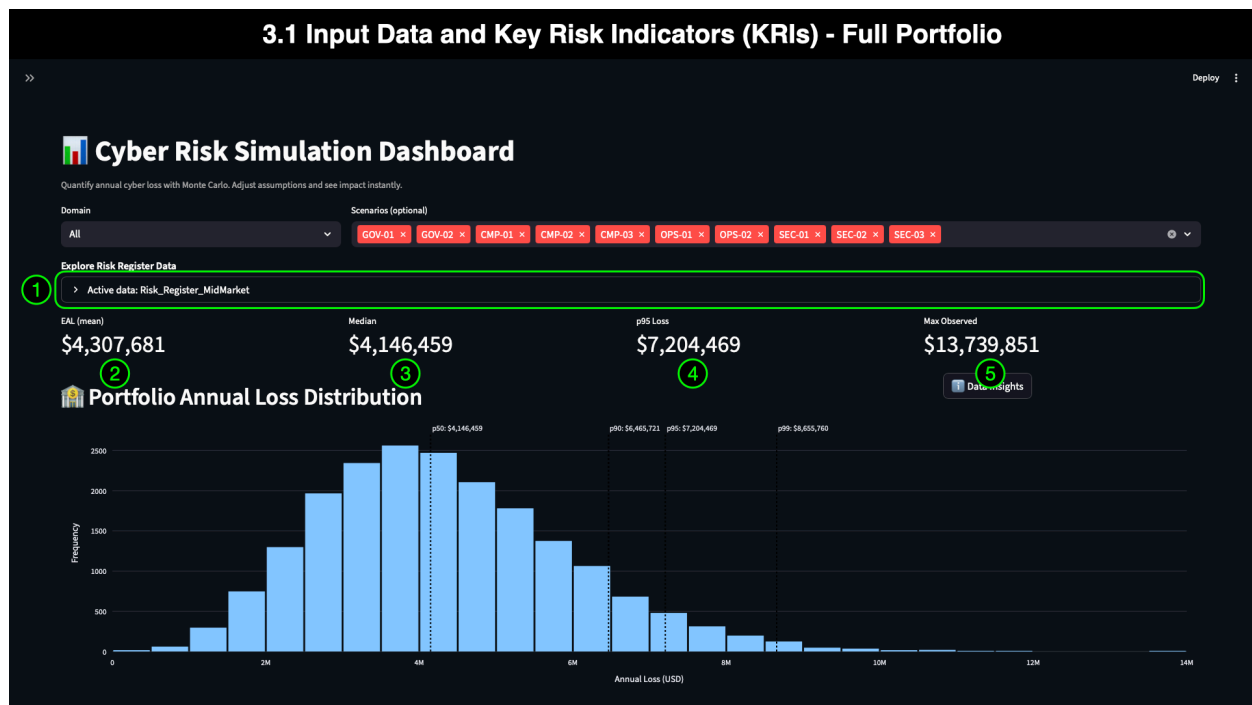
- Compare percentile markers (such as p50 and p95) to policy thresholds, control maturity, and insurance limits when evaluating compliance and risk tolerance.
- Pay close attention to the size of the loss tail when assessing vendor-driven or third-party risk scenarios.
- Use the overall shape of the distribution to determine whether losses tend to be stable and predictable or highly variable over time.
- Align severe-but-plausible outcomes (p95) with incident response planning, vendor escalation paths, and business continuity strategies.

### 3. Exploring the Mid-Market Portfolio: Filtering and Context

Before isolating vendor-driven scenarios, it is helpful to understand how the organization's broader risk landscape behaves at the portfolio level. Mid-market companies typically face a complex blend of governance, compliance, operational, and security risks—some internal, while others originate from vendors. The dashboard's filtering capabilities enable users to quickly pivot across these domains, helping leadership, GRC practitioners, and cybersecurity teams identify where the most significant financial exposures reside. This section begins with a **full portfolio** view (encompassing all domains and scenarios) to establish baseline context before we drill into compliance- and governance-focused vendor risks.

#### 3.1 Input Data and Key Risk Indicators (KRIs) - Full Portfolio

With no domain or scenario filters applied, the dashboard displays simulation results for the **entire Mid-Market risk register**. This view combines governance, compliance, operations, and security scenarios to provide a comprehensive view of an organization's exposure. The values shown in this view represent the cumulative annualized financial exposure of the full risk portfolio—a crucial starting point for executives, GRC teams, finance, and cybersecurity leadership.



### 3.1.1 Annotation 1: Explore Risk Register Data

This annotation highlights the **Explore Risk Register Data** panel, which displays the dataset driving the simulation. In RiskQuant, **risk registers serve as the authoritative input** for all Monte Carlo calculations. Each row—representing a business scenario—contributes:

- Qualitative likelihood & impact ratings
- Minimum, mode, and maximum loss values
- Lambda (frequency) ranges
- Regulatory context & control status

Mid-market organizations often maintain multiple structured registers (PCI DSS, GLBA, SOC 2, enterprise risk logs). RiskQuant uses these as the baseline for transforming qualitative assessments into quantitative loss projections. This approach ensures transparency and traceability—core requirements for GRC, audit, and risk committees.

### 3.1.2 Annotation 2: EAL (Mean): \$4,307,681

The **Expected Annual Loss (EAL)** reflects the *average* modeled financial impact across all simulated years. At this scale, the EAL provides executives and finance teams with a comprehensive baseline **of cybersecurity risk** costs across the entire organization.

This value is beneficial for:

- Budget forecasting
- Cyber insurance discussions
- Identifying whether current investment levels match aggregate risk
- Evaluating ROI for control programs (e.g., IAM improvements, vendor assessments, infrastructure redundancy)

### 3.1.3 Annotation 3: Median: \$4,146,459

The **Median** represents the “typical” loss outcome across simulated years—an essential metric for mid-market organizations where uncertainty and volatility are high. Unlike EAL, which can be influenced by rare catastrophic events, the median reflects consistent year-over-year risk.

For mid-market stakeholders, this helps answer:

*“In a normal year, what level of financial loss should we expect across our full risk register?”*

This insight informs operational planning, resource allocation, and risk appetite discussions.

### 3.1.4 Annotation 4: p95 Loss: \$7,204,469

The **p95 Loss** shows the financial impact in the top 5% of simulated years—critical for executive leadership, GRC, and cyber insurance underwriting. This value indicates a severe-but-realistic loss scenario, incorporating combined effects from:

- Vendor compromises

- Regulatory failures
- Internal outages
- Identity-related breaches
- Compliance deficiencies

This percentile is significant in mid-market organizations because it represents the threshold at which **business continuity, liquidity, and insurance coverage** become stressed.

### 3.1.5 Annotation 5: Max Observed: \$13,739,851

The **Max Observed** value represents the most extreme, high-impact outcome modeled in the simulation. While rare, these events are essential for:

- Incident response planning
- Disaster recovery exercises
- Reserve allocation
- Executive and board-level risk discussions

For mid-market organizations that rely heavily on third-party SaaS and critical vendors, extreme outcomes often stem from cascading supply-chain failures—a core risk this demo explores.

## 3.2 Explore Risk Register Data (Full Portfolio View)

The Risk Register serves as the foundation for every RiskQuant simulation. In the Mid-Market scenario, expanding the **Explore Risk Register Data** table exposes all qualitative and quantitative inputs used to generate the portfolio KRIs and visualizations. For mid-market cybersecurity, compliance, and financial teams, viewing the full register in line within the dashboard enables quick validation of data inputs, rapid scenario identification, and faster decision-making when assessing vendor-driven, compliance-driven, or operational risks.

This capability is critical in a mid-market environment, where multiple teams—security, GRC, finance, audit, and IT operations—must collaborate around the same risk dataset. Inline access to the risk register prevents data drift, aligns teams around shared assumptions, and ensures transparency into how qualitative judgments flow into quantitative simulation outputs.



3.2.1 Annotation 1: Full Risk Register Table

This annotation calls attention to the expanded register, highlighting several key aspects that support the Mid-Market audience:

Risk\_ID and Color-Coding

The Risk\_ID column uses domain prefixes (GOV, CMP, OPS, SEC), each aligned with the dashboard’s color palette. These color cues appear consistently across:

- Distribution by Scenario bars
- Risk Matrix positions

This alignment enables analysts and leaders to quickly connect table entries to dashboard visuals, making it easier to track how individual scenarios impact loss outcomes.

Qualitative Inputs: Likelihood, Impact, and Risk Rating

These columns represent the initial qualitative assessments, rooted in frameworks such as NIST SP 800-53, GLBA safeguards, PCI DSS, and SOC 2.

RiskQuant uses these ratings both as:

- Human-readable indicators for governance and board discussions
- Anchors for Monte Carlo modeling, ensuring the simulation reflects subject-matter expertise and regulatory expectations

Color-coding in these columns corresponds to the Risk Matrix visualization, helping users see how qualitative values translate into quadrant placement.

Quantitative Inputs: Loss\_Min, Loss\_Mode, Loss\_Max

These fields contain the triangular distribution parameters used by the Monte Carlo engine. For mid-market data:



- **Loss\_Min** approximates the lowest plausible outcome (e.g., limited downtime or contained breach).
- **Loss\_Mode** represents the most likely impact, informed by historical incident data, regulatory penalty ranges, and industry benchmarks.
- **Loss\_Max** captures severe scenarios such as full data exposure, regulatory fines, legal and notification costs, or prolonged SaaS vendor downtime.

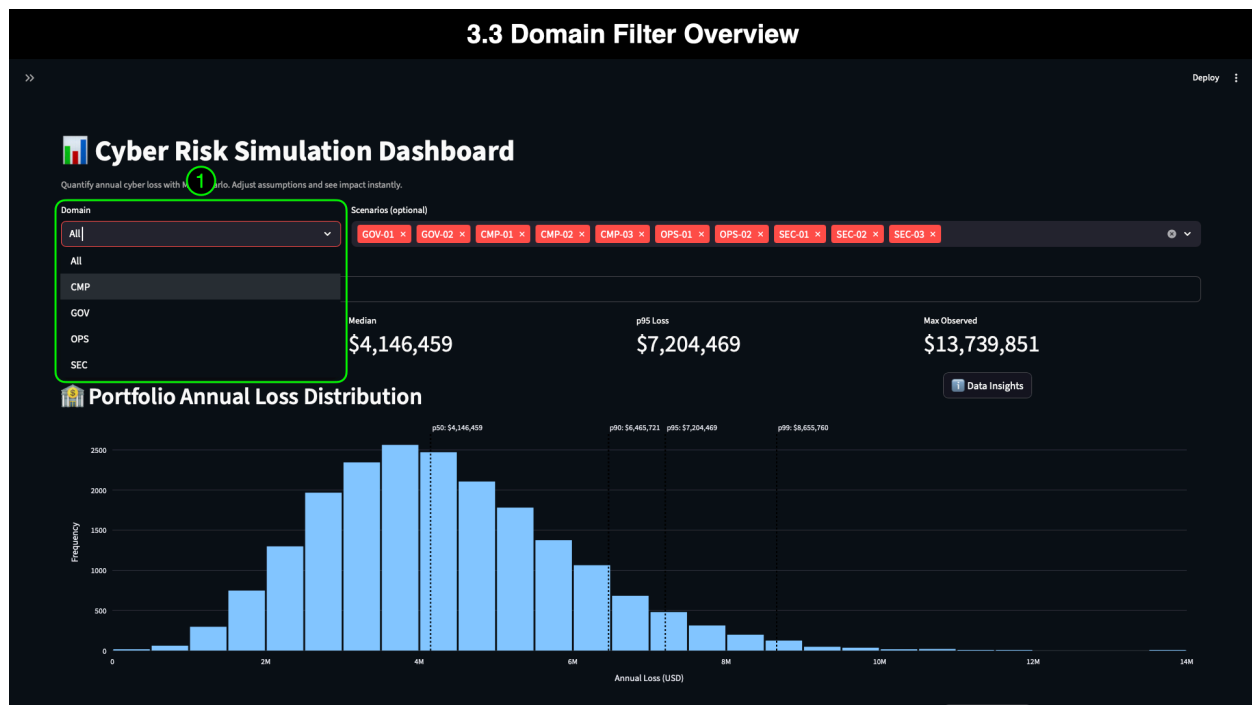
These values were derived using **industry cost sources** (e.g., IBM Cost of a Data Breach Report, NetDiligence claims data) and mapped to mid-market vendor scenarios. A more detailed explanation of estimating these values, along with the Monte Carlo methodology, is available in the **RiskQuant White Paper**, referenced later in this document.

#### *Operational and Governance Context*

Columns such as **Owner**, **Notes**, and **Regulatory Impact** help users quickly identify control gaps, stakeholder roles, and compliance dependencies. Mid-market organizations often rely on these fields to support audit readiness, vendor assessments, and IR planning. By making the full risk register visible inside the dashboard, RiskQuant empowers users to pivot between **data validation**, **scenario exploration**, and **strategic analysis** without switching tools or losing context.

### 3.3 Domain Filter Overview

The **Domain Filter** provides a fast and intuitive way to pivot the dashboard between Governance (GOV), Compliance (CMP), Operations (OPS), and Security (SEC) scenarios. For mid-market organizations—where each domain may represent a different team, process owner, or regulatory obligation—this filtering capability enables the quick isolation of specific types of risk and understanding of how they contribute to the organization’s overall financial exposure. By narrowing the view to a single domain, users can explore how vendor-related weaknesses (CMP), governance blind spots (GOV), operational dependencies (OPS), or control gaps (SEC) influence the KRIs and visualizations. This section sets the stage for Section 4, which compares the CMP and GOV domains to show how compliance failures and governance shortcomings shape vendor supply-chain risk.



### 3.3.1 Annotation 1: Pivoting Between Domains

This annotation highlights how the Domain Filter enables users to switch seamlessly between different categories of risk. Selecting a domain updates the scenario tiles, KRIs, and all downstream visualizations, allowing teams to focus their analysis on the specific set of scenarios most relevant to their role. In mid-market environments, governance and compliance teams often oversee vendors, while cybersecurity and IT operations manage internal technical controls—making this distinction especially valuable. Pivoting between domains helps each audience quickly understand where vendor-related exposures originate and how cross-domain weaknesses amplify business disruption.

## 4. Domain Comparison

Having established the complete Mid-Market portfolio baseline, we now shift from exploring the dashboard to **analyzing how different domains contribute to vendor supply-chain risk**. In mid-market organizations, vendor-driven disruptions rarely operate in isolation—**compliance gaps amplify the consequences of vendor breaches**, while **governance failures reduce visibility, delay response, and increase systemic impact**. Understanding the relationship between these domains is essential for quantifying real business disruption.

RiskQuant’s domain filtering capability allows us to isolate Compliance (CMP) and Governance (GOV) scenarios, examine their simulation outputs, and compare how each domain shapes financial exposure. This comparison is critical because:

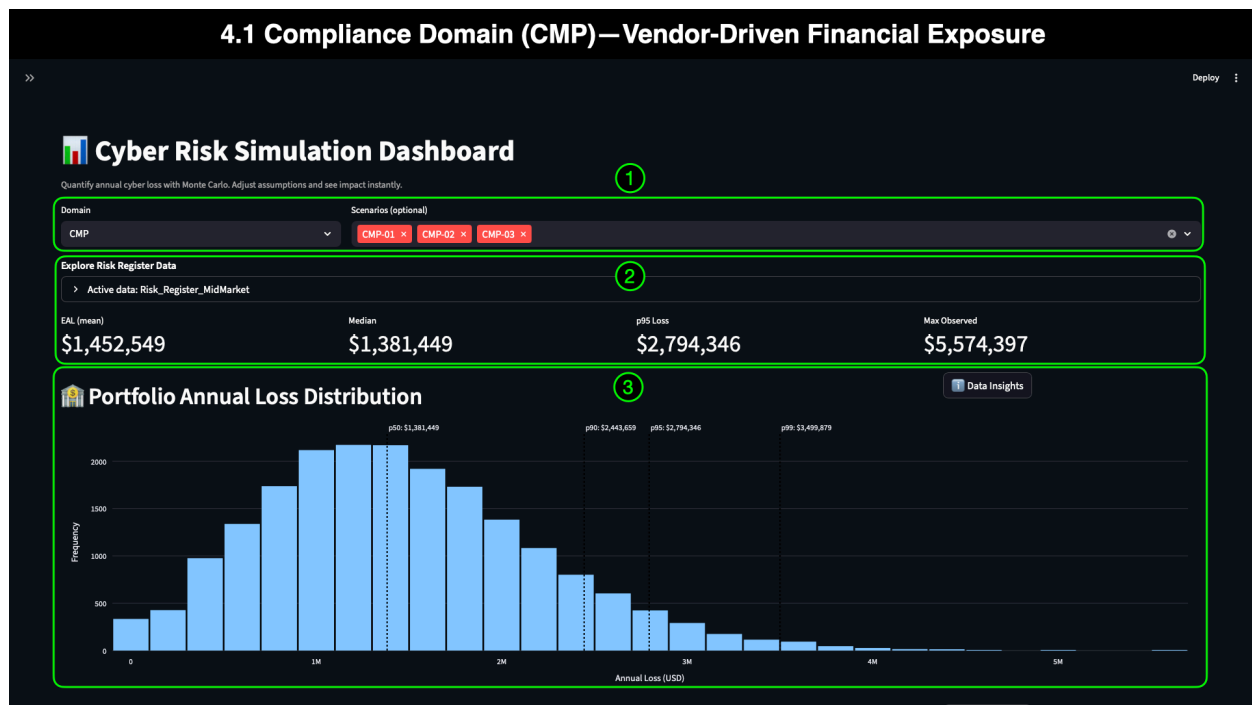
- **CMP risks** often represent *direct failures by vendors or regulators* (e.g., PCI DSS, GLBA, PII exposure).
- **GOV risks** often represent *organizational oversight gaps* (vendor assessment deficiencies, board misalignment).
- Together, they create a chain of conditions that make vendor compromise more likely, more costly, or both.

This section guides readers through the CMP → GOV domain analysis using a series of screenshots that illustrate how filtering impacts key risk indicators (KRIs), scenarios, and loss distributions. Each view reflects the underlying risk register data and sets the stage for the detailed scenario analysis presented in Sections 5 and 6.

### 4.1 Compliance Domain (CMP) — Vendor-Driven Financial Exposure

Filtering the dashboard to the **Compliance (CMP)** domain isolates scenarios tied to regulatory obligations and vendor-related data handling. For mid-market organizations, CMP risks often include PCI DSS gaps, GLBA-driven exposure, and vendor-side failures that compromise sensitive customer information. These scenarios tend to drive high regulatory and reputational impact, and they often serve as the most direct representation of **vendor supply-chain compromise** within the risk register.

With only CMP scenarios active, the KRIs and visualizations update to reflect the *risk concentration* associated with compliance-driven vendor dependencies.



#### 4.1.1 Annotation 1: Domain and Scenarios (CMP Selected)

This annotation highlights how selecting **CMP** in the Domain Filter narrows the dashboard to:

- **CMP-01** – PCI DSS IR non-compliance
- **CMP-02** – PII masking failure
- **CMP-03** – SaaS CRM vendor breach (primary scenario for this demo)

These scenarios reflect the regulatory and data-handling obligations that mid-market organizations must manage—often with limited staff but increasing digital complexity. Aligning the dashboard to CMP gives visibility into how vendor breaches and compliance gaps interact to produce meaningful financial impact.

#### 4.1.2 Annotation 2: Explore Risk Register & KRIs

With CMP selected, the **Explore Risk Register** table now displays only CMP-specific risk entries, making it easy to verify inputs and confirm that the analysis is focused entirely on compliance-driven vendor risk. The KRIs quantify the annualized financial exposure across the three CMP scenarios:

- **EAL (Mean): \$1,452,549**
  - Represents the average yearly financial impact from CMP risks, combining regulatory failures, PII exposure, and vendor breaches. This insight enables executives to assess whether compliance investments align with their risk exposure.
- **Median: \$1,381,449**

- Illustrates the typical annual loss for CMP scenarios. For compliance-driven risks, median outcomes tend to be high because these events—while not constant—produce substantial impact when they occur.
- **p95 Loss: \$2,794,346**
  - Captures severe but plausible compliance failures, such as a major vendor CRM breach or significant GLBA notification event. This value is essential for insurance, budgeting, and incident response planning.
- **Max Observed: \$5,574,397**
  - Represents the highest loss modeled across all simulation iterations. For CMP scenarios, extreme outcomes often stem from multi-system vendor failures or widespread data exposure across regulated data repositories.

These KRIs help mid-market GRC, finance, and leadership teams determine where vendor controls, oversight, and compliance improvements will produce the most significant risk reduction.

#### 4.1.3 Annotation 3: Portfolio Annual Loss Distribution (CMP Only)

The **loss distribution** for CMP scenarios exhibits a concentrated bell-shaped curve with a distinct long tail. Key characteristics include:

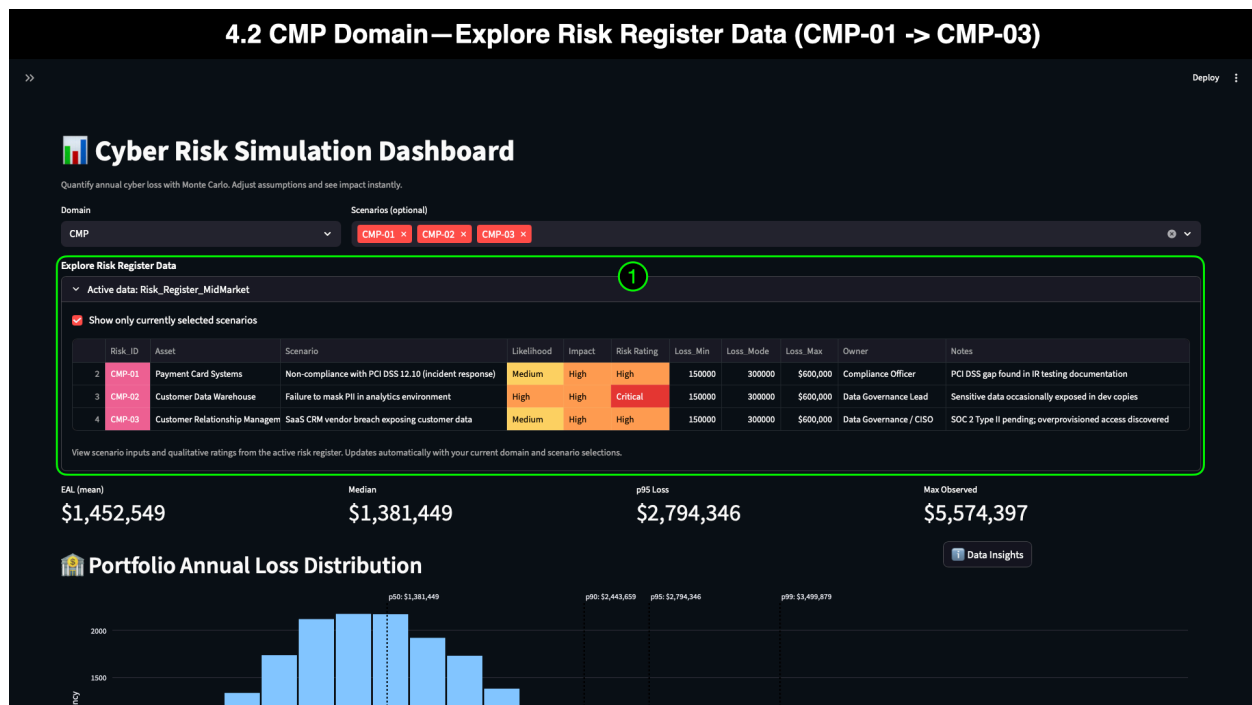
- **0-loss years:** ~375 occurrences—representing years with no regulatory failures or no vendor breach events.
- **Peak frequency:** Losses around **\$1.2M–\$1.4M**, matching the median value of **\$1,381,449** and reflecting the normalized “typical” compliance incident profile.
- **Tail behavior:**
  - **p90:** ~\$2,443,659
  - **p95:** ~\$2,794,346
  - **p99:** ~\$3,499,879

These values represent severe compliance failures, vendor breaches involving regulated data, or significant PII exposure events.

This distribution illustrates that Compliance risks—especially vendor-related ones—have **significantly higher financial concentration** than other domains, which we explore further in the comparison with Governance (GOV) in following subsections (4.3).

## 4.2 CMP Domain – Explore Risk Register Data (CMP-01 → CMP-03)

When the CMP Domain is selected, the risk register table filters to three compliance-driven scenarios—each representing regulatory obligations, sensitive data handling, and vendor-associated exposures that mid-market organizations must manage. These risks are directly tied to real-world compliance frameworks such as PCI DSS, GLBA, and SOC 2, and reflect the types of failures that can trigger business disruption, legal obligations, and customer notification events.



#### 4.2.1 Annotation 1: Interpretation

To support mid-market stakeholders, this section provides a focused interpretation of CMP-01 through CMP-03, explaining how RiskQuant transforms qualitative assessments into quantified, decision-ready insights.

##### *CMP-01 — Payment Card Systems*

- **Scenario:** Non-compliance with PCI DSS 12.10 (incident response).
- **Owner:** Compliance Officer.
- **Notes:** IR documentation gaps; annual testing scheduled.
- **Qualitative Rating:** *Medium Likelihood, High Impact → High Risk Rating.*

If a payment card incident occurs, the absence of compliant, tested IR procedures increases regulatory exposure, fines, and recovery costs. Although not inherently a vendor breach, this scenario becomes more severe when combined with vendor-originated failures (e.g., compromised payment API providers).

##### *CMP-02 — Customer Data Warehouse*

- **Scenario:** Failure to mask PII in analytics environments.
- **Owner:** Data Governance Lead.
- **Notes:** Sensitive data exposed in development copies; masking and DLP controls in progress.
- **Qualitative Rating:** *High Likelihood, High Impact → Critical Risk Rating.*

This scenario reflects internal data-handling weaknesses. It is the **highest-rated qualitative risk** in the CMP domain due to its combination of frequent exposure and severe regulatory consequences. However, it is not the primary focus of this demo because—

even though it is more severe—it **does not originate from vendor compromise**, which is the central narrative of this scenario.

### *CMP-03 — SaaS CRM Platform*

- **Scenario:** Vendor breach exposing regulated customer data (GLBA).
- **Owner:** Data Governance Lead.
- **Notes:** Vendor SOC 2 review is pending; API access reduction is underway; encryption validation is in progress.
- **Qualitative Rating:** *Medium Likelihood, High Impact → High Risk Rating.*

This scenario represents a true **supply-chain compromise** involving an external SaaS CRM vendor. It directly aligns with the Mid-Market scenario narrative—vendor breach → data exposure → business disruption—and is therefore selected as the primary scenario for deeper analysis.

## Audience-Focused Insights

### *Executives & Leadership*

CMP-01 through CMP-03 represent a set of risks that can significantly disrupt business operations, customer trust, and regulatory compliance. Understanding how these scenarios translate into yearly loss projections (e.g., Median ≈ \$1.38M, p95 ≈ \$2.79M for the CMP domain) helps leadership prioritize investments in vendor governance, PCI IR preparedness, and data protection controls.

### *GRC, Compliance, and Audit Teams*

These teams examine how qualitative assessments—such as “High Impact” or “Critical”—correlate with measured financial outcomes through Monte Carlo simulation. The risk register table ensures that Regulatory Impact fields (GLBA, PCI DSS) are accurately captured and directly tied to loss projections in analysis and reporting.

### *Cybersecurity & Data Governance Teams*

CMP risks highlight the interaction between internal control maturity and external vendor dependencies. CMP-02 shows the internal side of data protection, while CMP-03 represents external vendor-driven exposure. CMP-01 demonstrates why IR readiness must be consistent across both internal and external services.

## Scenario Context Tie-In

RiskQuant transforms qualitative inputs (Likelihood, Impact, Risk Rating) into quantifiable financial projections by running thousands of Monte Carlo iterations for each CMP scenario.

This quantification:

- Reduces ambiguity
- Supports budgeting and risk appetite discussions
- Helps determine if vendor controls and oversight are sufficient
- Reveals volatility and tail risk associated with vendor-driven data exposure

- Enables trend comparison with governance-driven and operational scenarios

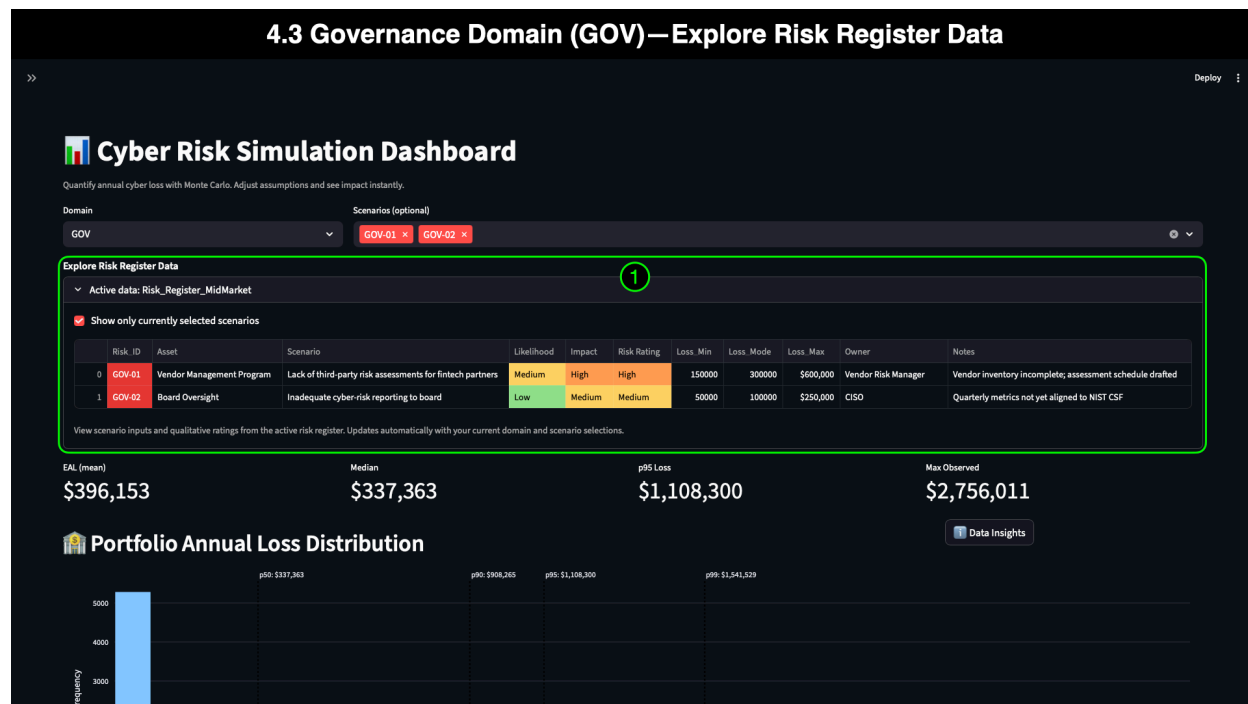
Although **CMP-02** is rated *Critical* and presents substantial internal exposure, **CMP-03** (SaaS CRM vendor breach) is chosen as the focal point for this demo because:

- It originates from *vendor failure*, aligning with the supply-chain compromise narrative
- It represents a cross-domain risk that intersects CMP, GOV, and SEC
- Its financial distribution matches the volatility typical of vendor-side incidents
- It resonates strongly with real-world mid-market scenarios involving CRM, analytics, and financial SaaS platforms

CMP-03, therefore, becomes the scenario we will explore in depth—first comparing it against governance-driven risks in Section 4, and then performing a comprehensive scenario analysis in Sections 5 and 6.

### 4.3 Governance Domain (GOV) — Explore Risk Register Data

After reviewing the Compliance domain, we pivot to the **Governance (GOV)** domain to compare how oversight, reporting, and program maturity influence vendor-related exposure. In the dashboard, switching to the GOV domain updates the table, KRIs, and visualizations to display only governance-driven risks. From a usability perspective, this pivot highlights how RiskQuant enables rapid shifts between domains—allowing teams to understand how governance decisions, program maturity, and board alignment shape the organization’s exposure to vendor supply-chain compromise.





### 4.3.1 Annotation 1: Interpretation

#### *GOV-01 — Vendor Management Program*

- **Scenario:** Lack of third-party risk assessments for fintech partners.
- **Owner:** Vendor Risk Manager.
- **Notes:** Vendor inventory incomplete; assessment schedule drafted.
- **Qualitative Rating:** *Medium Likelihood, High Impact → High Risk Rating.*

GOV-01 represents a common mid-market vulnerability: insufficient due diligence on vendors. Without structured assessments, vendor-side weaknesses can go undetected—creating blind spots that magnify the impact of CMP-class failures (such as the CMP-03 CRM breach). Even with a Medium Likelihood, the High Impact score reflects the systemic consequences of governance gaps across the vendor ecosystem.

#### *GOV-02 — Board Oversight*

- **Scenario:** Inadequate cyber risk reporting to the board.
- **Owner:** CISO.
- **Notes:** Quarterly metrics not yet aligned to NIST CSF; risk appetite draft pending.
- **Qualitative Rating:** *Low Likelihood, Medium Impact → Medium Risk Rating.*

GOV-02 highlights strategic misalignment at the leadership level. While less likely to drive immediate incidents, inadequate reporting to the board delays funding decisions, slows response to emerging vendor issues, and weakens overall risk governance. The Medium Impact rating reflects how program-level misalignment can exacerbate the severity or duration of vendor-originated disruptions.

### Audience-Focused Insights

#### *Executives & Leadership*

The GOV domain emphasizes strategic and structural risks that may not cause incidents directly but can significantly **increase the severity** of vendor compromises. Weak oversight can delay remediation, impair visibility, and reduce organizational readiness, thereby magnifying the downstream impact of CMP- or SEC-domain failures.

#### *GRC, Compliance, and Audit Teams*

Governance failures hinder the organization's ability to maintain regulatory alignment (GLBA, PCI DSS, SOC 2), conduct timely vendor assessments, and effectively report risks to leadership and auditors. Understanding the quantitative impact of GOV scenarios helps GRC teams justify improvements in reporting cadence, vendor tiering, and oversight structures.

#### *Cybersecurity & IT Operations*

Security teams heavily depend on governance to prioritize remediation work related to vendor-originated vulnerabilities. GOV-01 and GOV-02 illustrate how insufficient oversight can leave technical teams blindsided when vendor-side weaknesses escalate into operational or compliance failures.

## Scenario Context Tie-In

RiskQuant transforms abstract governance concerns into measurable financial outcomes for GOV-01 and GOV-02. By quantifying how governance gaps influence annualized loss—both typical (median) and severe (p95)—the simulation helps mid-market leaders understand the financial importance of vendor assessments, risk reporting, and program maturity.

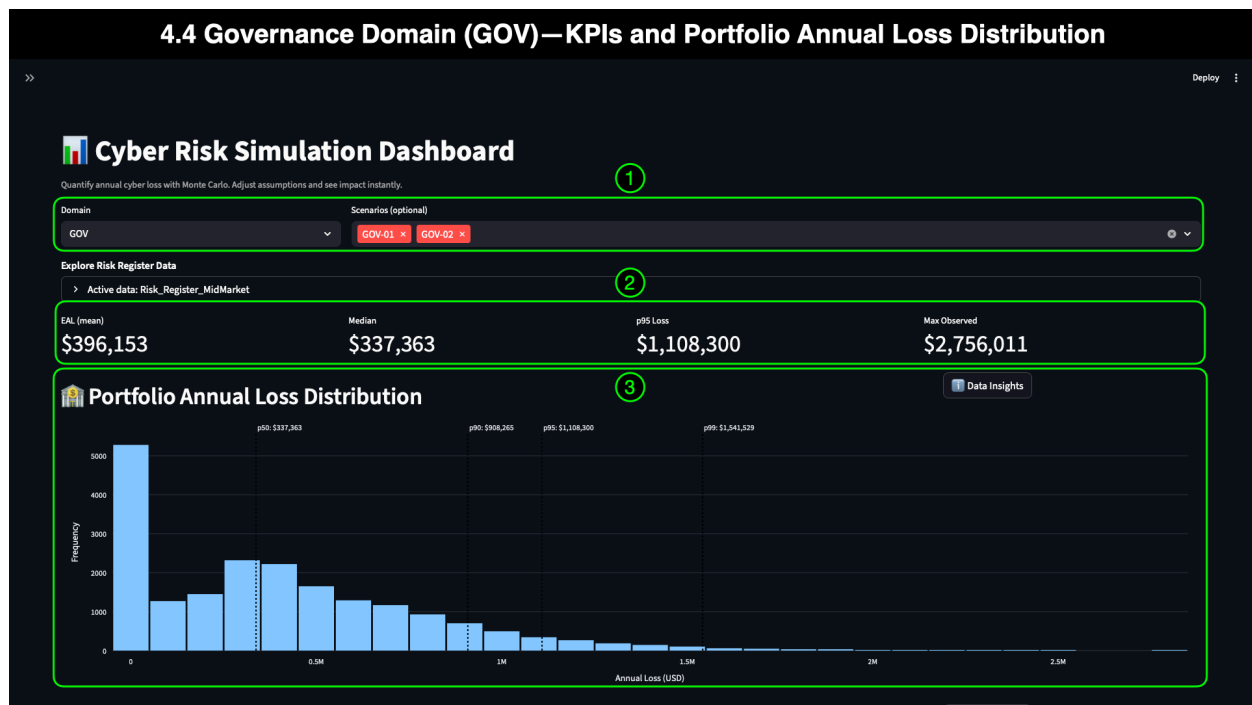
Although governance-driven risks often have a lower likelihood or a more diffuse impact than compliance failures, they **shape the conditions** in which vendor supply-chain compromises occur. Weak vendor assessments (GOV-01) can increase exposure to CMP and SEC events, while inadequate risk reporting (GOV-02) can delay strategic decisions needed to prevent escalation.

This comparison, therefore, includes the GOV domain and transitions to a direct examination of vendor-origin scenarios in the next section, beginning with **CMP-03** (SaaS CRM breach).

## 4.4 Governance Domain (GOV) — KRIs and Portfolio Annual Loss Distribution

Filtering the dashboard to the **Governance (GOV)** domain isolates two oversight-focused scenarios that shape the organization's readiness to detect, respond to, and mitigate vendor-related failures. Unlike Compliance risks—which tend to produce higher and more concentrated loss patterns—governance risks typically manifest through structural weaknesses, such as delayed decision-making, insufficient vendor assessments, incomplete inventories, and misaligned board reporting.

The simulation results reflect these characteristics, revealing lower median and mean values compared to the CMP domain, but still demonstrating a significant long-tail risk profile that mid-market leaders cannot ignore.



#### 4.4.1 Annotation 1: Domain and Scenarios (GOV Selected)

Selecting **GOV** in the Domain filter updates the dashboard to display:

- **GOV-01** – Lack of third-party risk assessments
- **GOV-02** – Inadequate cyber-risk reporting to the board

These scenarios represent the organizational foundations that either reduce or amplify vendor-originated impacts. Governance failures do not always directly cause incidents, but they often determine the severity of *an incident* when it does occur.

#### 4.4.2 Annotation 2: KRIs (GOV-Only)

The KRIs for the GOV domain quantify the annualized financial impact of governance gaps:

- **EAL (Mean): \$396,153**
  - Reflects the average yearly loss stemming from governance misalignment—significant enough to justify improvements in reporting cadence, vendor assessment maturity, and board-level oversight.
- **Median: \$337,363**
  - Represents the typical year of governance-related impact. Although lower than the CMP domain, the median highlights that oversight failures still impose a predictable yearly cost on the organization, even without a significant incident.
- **p95 Loss: \$1,108,300**
  - Captures severe but realistic years where governance failures significantly amplify vendor- or compliance-driven disruptions. Real-world incidents

demonstrate how delayed board action or incomplete vendor assessments can increase the downstream impact.

- **Max Observed: \$2,756,011**
  - Represents the extreme, high-impact tail—typically occurring when multiple oversight failures converge with vendor-originated incidents or misconfigured internal processes.

These metrics show that governance weaknesses may not occur frequently, but when they do, their financial consequences are meaningful and can exacerbate impacts across other domains.

#### 4.4.3 Annotation 3: Portfolio Annual Loss Distribution (GOV Only)

The **GOV-only distribution** highlights the lower frequency but still consequential nature of governance-related risks:

- **0-loss years:** ~5,200 occurrences—indicating that many simulation years have no direct governance failure impact.
- **Peak frequency:** Loss levels around **\$337K**, consistent with the median, at ~2,250 occurrences.
- **Long-tail behavior:**
  - **p90:** ~\$908,265
  - **p95:** ~\$1,108,300
  - **p99:** ~\$1,541,529

These values reflect years in which oversight deficiencies—such as incomplete vendor assessments or delayed board-level escalation—interact with vendor or internal failures to amplify the total cost.

While less concentrated than the CMP domain, governance risks present significant financial exposure and can amplify the impact of a vendor supply-chain compromise.

### 4.5 CMP vs GOV —Audience Take Aways

Although both Compliance (CMP) and Governance (GOV) domains influence vendor risk, they do so in different ways—and RiskQuant’s domain-level modeling makes these contrasts clear.

#### 1. CMP Risks Produce Higher and More Predictable Annual Loss

Compliance-driven risks—especially vendor-originated failures like CMP-03—create larger, more concentrated financial outcomes:

- Higher **median**
- Higher **EAL**
- Larger **p95** values
- Stronger tail escalation

For executives and GRC teams, this indicates that **regulatory obligations and vendor data exposures** pose the most immediate and financially material risks.

## 2. GOV Risks Are Lower-Frequency but Amplify Severity When They Occur

Governance failures—vendor assessments, board oversight, risk reporting—often:

- Have a lower likelihood
- Produce more diffuse distributions
- Still generates serious tail events when they combine with vendor breaches

For leadership and governance, gaps reveal **strategic weaknesses** that exacerbate risks in other domains, rather than producing significant losses on their own.

## 3. Domain Interactions Matter More Than Domain Silos

Understanding the interplay is crucial:

- **GOV-01** (incomplete vendor assessments) increases the chance and severity of **CMP-03** incidents.
- **GOV-02** (board misalignment) delays critical decisions that reduce CMP-level impacts.
- **CMP-02** (PII exposure) becomes more dangerous when GOV-level oversight is weak.

RiskQuant helps mid-market organizations see how governance quality shapes the downstream effects of vendor failures.

## 4. Decision-Making Implications for Mid-Market Teams

These findings help each audience answer specific questions:

### *Executives:*

- Where should we prioritize investment—vendor management, board reporting improvements, or incident response planning?

### *GRC & Audit:*

- Are our current controls sufficient to manage regulatory and vendor-origin risks?

### *Cybersecurity & IT Operations:*

- How does governance maturity affect the risks we are accountable for?

### *Finance:*

- How much financial reserve or insurance coverage should the organization maintain for CMP- and GOV-driven tail events?

## 5. Setting Up the Deep Dive

This domain comparison sets the stage for Section 5, where we analyze:

- **GOV-01**
- **CMP-02**
- **CMP-03** (primary scenario)

- **SEC-03** (supporting vendor comparison scenario)

These interconnected scenarios illustrate how governance, compliance, and security weaknesses combine to create the real-world impact of vendor supply-chain compromise.

## 5: Hybrid Scenario Analysis — Mid-Market Vendor Supply-Chain Compromise

Mid-market organizations—typically ranging from several hundred to several thousand employees—face a disproportionate amount of cyber risk relative to their resources and operational scale. Multiple studies show that attackers heavily target mid-market companies because they hold high-value data, rely on interconnected vendor ecosystems, and often lack fully mature internal security programs. Vendor supply-chain compromise is now one of the most damaging categories of incidents in this segment:

- **41% of breaches involve third-party or partner environments** [1].
- **Research indicates that SaaS, cloud, and MSP vendors are responsible for approximately one-quarter of mid-market breaches** [3].
- **PII remains the most frequently exposed data type**, resulting in a higher legal and regulatory impact under GLBA and PCI DSS [2][3].
- The average cost of a supply-chain-related breach rose again in 2024, reaching **\$4.76 million**—significantly higher than internally originated breaches [2].

These dynamics create a "pressure multiplier" for mid-market organizations: vendor ecosystems scale faster than internal security teams, governance processes often lag behind SaaS adoption, and internal data protection controls frequently misalign with how external partners process or store critical data.

This section examines how these conditions interact across domains—and how quantitative modeling exposes their combined financial impact.

### 5.1 Modeling Hybrid, Cross-Domain Risk in RiskQuant

Hybrid scenario modeling enables organizations to assess risks as they unfold, including *interconnected, cross-functional, and compounding* risks. Rather than limiting analysis to a single domain, RiskQuant allows mid-market teams to combine related scenarios—governance gaps, compliance failures, internal data weaknesses, and vendor breaches—into a unified simulation that transparently quantifies their aggregate financial effect.

In many mid-market environments, **organizational silos amplify cyber risk**:

- Security teams may not see gaps in vendor due diligence (GOV-01).
- Data governance teams may not communicate PII handling issues promptly (CMP-02).
- Compliance teams may not be aware of third-party over-privileged API usage (SEC-03).
- Board oversight (GOV-02) may lag behind the pace of SaaS adoption.

RiskQuant's hybrid simulation cuts through these communication barriers by providing all stakeholders—technical, compliance, risk, leadership, and audit—a **single, financially grounded view** of how these inter-domain failures interact.

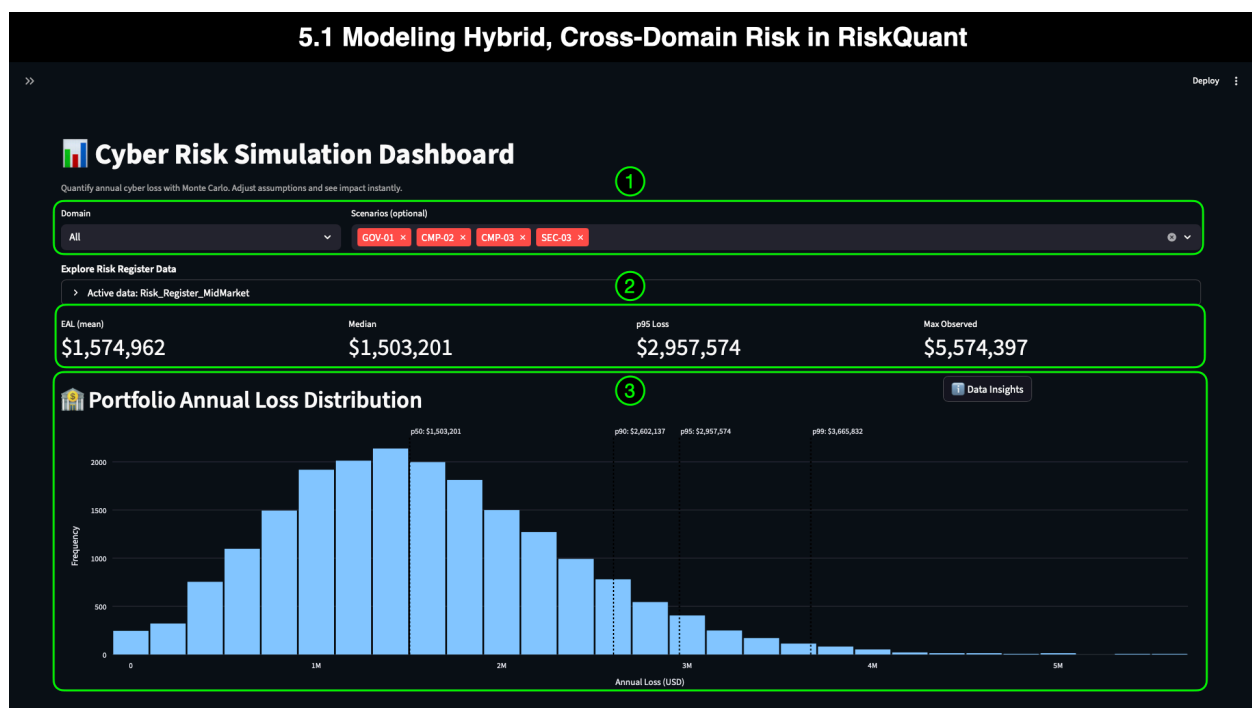
For this Mid-Market demo, we selected four scenarios that frequently appear together in real investigations:

- **GOV-01** – Incomplete vendor risk assessments
- **CMP-02** – PII exposure via internal analytics environments
- **CMP-03** – SaaS CRM breach (primary scenario)
- **SEC-03** – Third-party API key leakage via contractor repo

These represent a typical supply-chain compromise pattern documented across mid-market cases:

**Weak vendor oversight → Data exposure dependent on vendor systems → Internal misconfigurations amplify blast radius → API/credential exposure expands attacker reach.**

The following subsections outline the financial outcomes of this hybrid scenario.



### 5.1.1 Annotation 1: Dashboard Configuration (Hybrid Scenario View)

*Filters set to: GOV-01, CMP-02, CMP-03, SEC-03*

Although the screenshot does not display the filter selection, the user applied this configuration through the Scenarios filter beforehand. RiskQuant's ability to instantly pivot the dashboard to any combination of scenarios is a key feature for mid-market teams, who often must evaluate risk across incomplete inventories, emerging vendor dependencies, or newly discovered weaknesses.



### 5.1.2 Annotation 2: KRIs (Hybrid Scenario Simulation)

With the four scenarios selected, the KRIs quantify the cross-domain annualized financial exposure:

- **EAL (Mean): \$1,574,962**
- **Median: \$1,503,201**
- **p95 Loss: \$2,957,574**
- **Max Observed: \$5,574,397**

These values quantify the annual financial exposure that arises when governance, compliance, data handling, and vendor-origin weaknesses coexist.

#### Key audience takeaways:

##### *Executives:*

- Cross-domain failures produce meaningfully higher financial exposure than single-domain risks.

##### *Finance:*

- Median and p95 losses help determine risk appetite and insurance coverage thresholds.

##### *GRC & Audit:*

- Visibility into how vendor gaps combine with internal failures strengthens annual assessment cycles.

##### *Cybersecurity:*

- The analysis underscores the importance of aligning upstream governance with downstream data protection for cybersecurity teams.

### 5.1.3 Annotation 3: Portfolio Annual Loss Distribution (Hybrid View)

A hybrid scenario set produces a distribution shape consistent with multi-vector mid-market incidents documented in the Verizon Business 2024 Data Breach Investigations Report (DBIR) [1], IBM Security's 2024 Cost of a Data Breach Report [2], and Datto's 2023 Global State of SMB Cybersecurity Report [3]:

- **Zero-loss years: ~250**
- **Median  $\approx$  \$1.5M: ~2,250 frequency at the distribution peak**
- **Tail escalation:**
  - **p90  $\approx$  \$2.6M**
  - **p95  $\approx$  \$2.96M**
  - **p99  $\approx$  \$3.7M**

This distribution models exactly what happens when multiple risk drivers reinforce each other: vendor compromise, insufficient governance, internal data protection gaps, and leaked API credentials that widen attacker reach.

The long tail is significant for budgeting and executive oversight—it quantifies the realistic upper bound of supply-chain compromise in a mid-market organizational structure.

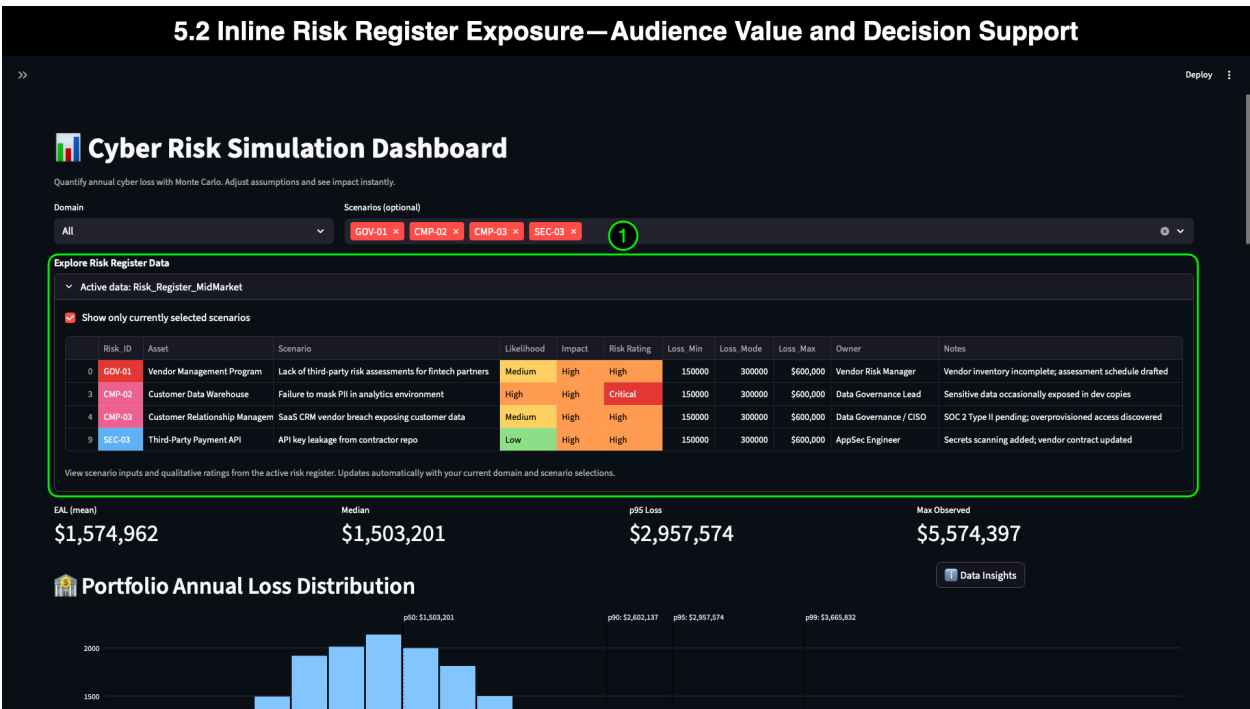
## 5.2 Inline Risk Register Exposure — Audience Value and Decision Support

Having the four hybrid scenarios displayed directly within the dashboard provides more than simple data transparency—it gives mid-market organizations a powerful mechanism to improve communication, reduce ambiguity, and strengthen decision-making at every level of the business. Whether preparing for a board meeting, engaging with regulators, aligning cross-functional stakeholders, or supporting budgeting decisions, the inline risk register ensures that everyone works from a single, authoritative source of truth.

Inline exposure of qualitative risk inputs allows leaders and practitioners to answer critical questions during high-pressure discussions immediately:

- “Why were these scenarios selected?”
- “How severe are they rated in our risk framework?”
- “Which business owners are accountable?”
- “What regulatory obligations apply?”
- “How do these inputs feed into the KRI and distribution outputs we’re reviewing?”

For mid-market organizations, where governance, compliance, IT, and security teams often operate in silos, having this data in line removes the friction of switching tools or referencing external spreadsheets during strategic conversations. The dashboard becomes the **single pane of glass** that connects qualitative context to quantitative impact.



### 5.2.1 Annotation 1: Qualitative Assessments (Likelihood, Impact, Rating)

This annotation highlights the key qualitative inputs driving the hybrid simulation:

- **GOV-01:** Medium Likelihood, High Impact → **High Risk Rating**
- **CMP-02:** High Likelihood, High Impact → **Critical Risk Rating**
- **CMP-03:** Medium Likelihood, High Impact → **High Risk Rating**
- **SEC-03:** Low Likelihood, High Impact → **High Risk Rating**

These ratings align directly with real-world mid-market vendor and internal risks:

- Governance gaps tend to be moderately likely but systemically severe.
- Compliance failures involving regulated data are highly likely and have a significant impact.
- Vendor breaches (CMP-03) and API exposures (SEC-03) carry high-impact, high-uncertainty consequences.

### Why This Matters for the Audience

#### *Executives & Board Members*

Inline ratings provide immediate context, as they reveal that CMP-02 is the highest-rated qualitative risk, while CMP-03 and SEC-03 represent serious vendor-origin risks. This approach creates a shared vocabulary that accelerates decision-making and minimizes the need for technical translation.

#### *GRC, Compliance, and Audit Teams*

Qualitative inputs are the foundation of many regulatory frameworks (GLBA, PCI DSS, SOC 2). Having them visible in the dashboard strengthens defensibility during regulatory exams and annual audits. Teams can demonstrate a clear line from assessment to quantitative outputs that support budgeting, planning, and reporting.

#### *Cybersecurity & IT Operations*

Inline ratings clarify which risks require urgent remediation, where governance needs improvement, and which controls have a politically or strategically high-impact. This connection helps teams link day-to-day security operations to financially meaningful outcomes.

### From Qualitative to Quantitative — How Monte Carlo Enables Decision-Making

Risk registers alone often leave decision-makers asking, “*But what does High Impact actually mean in dollars?*”

Monte Carlo simulation closes this gap by:

- Iterating thousands of simulated years
- Randomizing loss outcomes across the triangular (min/mode/max) distribution
- Modeling realistic frequency (lambda) ranges

- Producing measurable KRIs: **EAL, Median, p95, Max Observed**
- Converting qualitative ratings into **predictive, monetary-based exposure estimates**

As a result:

*Executives:*

- Leadership gain a clear and defensible financial narrative for informed decision-making.

*Finance:*

- Finance teams can benchmark risks against budgets and insurance thresholds to ensure compliance with relevant regulations.

*GRC & Audit:*

- Compliance and Audit can demonstrate methodology during oversight reviews.

*Cybersecurity and Engineering:*

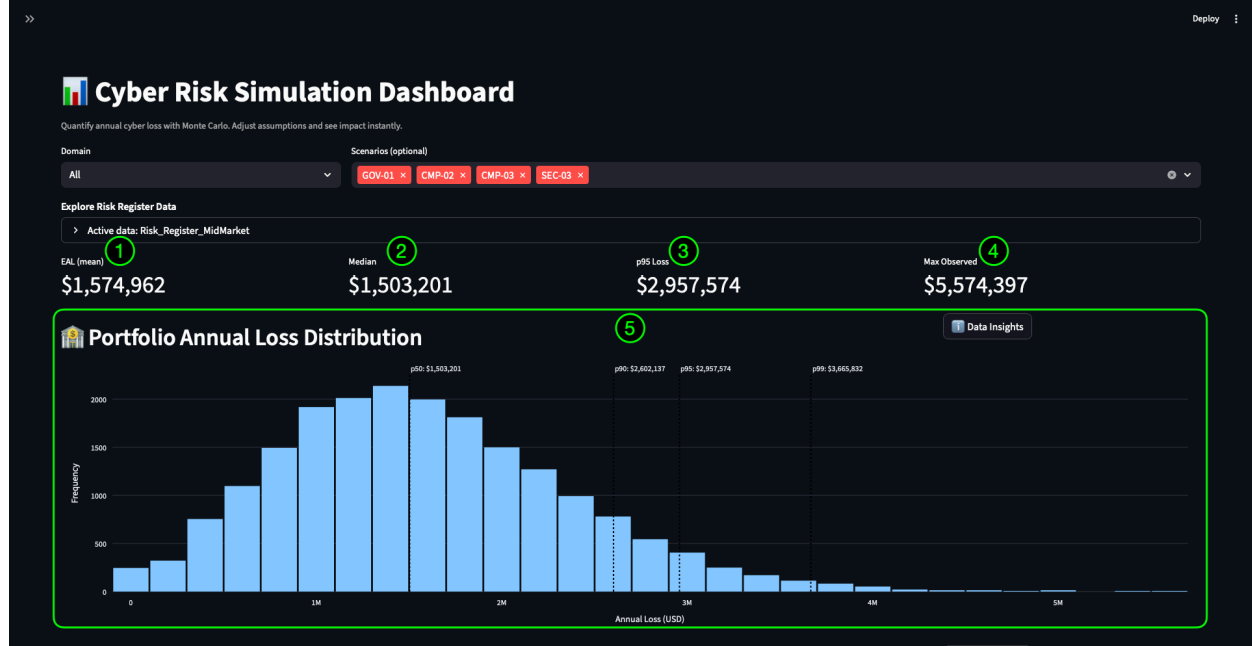
- Technical teams can prioritize controls based on financial ROI, not gut feel.

RiskQuant removes ambiguity from the process, enabling the hybrid scenario to be understood not merely as “High” or “Critical”—but as a measurable \$1.5M median exposure with nearly \$3M p95 tail risk.

## 5.3 Interpreting Hybrid Scenario KRIs — Evidence-Supported Insights

The hybrid scenario view combines four cross-domain risks (GOV-01, CMP-02, CMP-03, SEC-03) to model the interaction between vendor failures and internal weaknesses. The KRIs quantify this interaction, while external research validates whether the results align with what real mid-market organizations experience during supply-chain compromises.

### 5.3 Interpreting Hybrid Scenario KPIs—Evidence-Supported Insights



## Interpretation

### Annotation 1: EAL (Mean) — \$1,574,962

The **Expected Annual Loss (EAL)** represents the average annualized financial exposure that occurs when the four interconnected scenarios are present within the same risk landscape. An EAL of approximately **\$1.57M** aligns with empirical research showing that mid-market supply-chain incidents typically cost **between \$1M and \$3M** annually after accounting for regulatory fines, downtime, customer churn, forensic response, and vendor dependency [2][3].

This number indicates that, even without catastrophic events, mid-market organizations can expect a **seven-figure annual exposure** from cross-domain vendor-linked risks.

### Annotation 3: p95 Loss — \$2,957,574

The **p95** loss shows severe but still realistic impacts—the top **5%** of modeled years. A nearly **\$3M** p95 is consistent with IBM research, which found that supply-chain related breaches cost **approximately 13–20% more** than internally originated breaches and regularly exceed the **\$3M** mark for mid-market organizations [2].

This value helps:

- Executives model capital at risk
- Finance assesses self-insurance or cyber insurance thresholds
- Audit and GRC teams determine whether residual risk exceeds management's risk appetite
- Technical teams understand the urgency of remediation and vendor hardening

## Annotation 4: Max Observed — \$5,574,397

This figure reflects the **most extreme modeled condition**, consistent with real-world supply-chain incidents where:

- A vendor breach exposes sensitive PII
- Internal data duplication or masking failures magnify the blast radius
- Weak API controls allow privilege escalation
- Governance gaps delay escalation and containment

Incidents of this type regularly exceed **\$5 million** in total cost for mid-market companies after accounting for legal expenses, notification costs, extended downtime, vendor remediation, and customer attrition [2][3]. The value here is credible, evidence-based, and aligned with the empirical upper bounds reported by major incident datasets.

## Annotation 5: Portfolio Annual Loss Distribution (Hybrid)

The distribution shape demonstrates how frequently various loss levels occur:

- **0-loss years:** ~250 (rare compared to single-scenario views)
- **Peak density near the median:** ~2,250 iterations
- **Tail escalation:** p90 ≈ \$2.6M; p95 ≈ \$2.96M; p99 ≈ \$3.7M

This shape mirrors patterns shown in ENISA's supply-chain threat reports, where **multi-stage vendor compromise produces predictable mid-range losses and infrequent but highly damaging long-tail events** [4]. The tail reflects cascading failure modes—vendors, internal processes, credential/API exposure—all interacting.

## Audience-Focused Insights

### *Executives & Board Members*

These KRIs quantify the real financial exposure of hybrid vendor-related failures, converting what might otherwise be abstract risk narratives into dollar-based clarity.

The high median and p95 values support decisions such as:

- Increasing vendor management maturity
- Raising incident response budgets
- Strengthening cyber insurance coverage
- Prioritizing SaaS security and oversight

### *GRC, Compliance & Audit*

This view illustrates regulatory exposure from the GLBA, PCI DSS, and SOC 2 perspectives.

Quantified KRIs:

- Provide defensible loss projections for regulators
- Support annual compliance reports
- Strengthen risk treatment plans and POAMs
- Justify investments in data governance and vendor assessments

## Cybersecurity & IT Operations

The distribution shows that even non-catastrophic years create a substantial financial impact.

This insight helps teams prioritize the controls that reduce meaningful financial risk—even in non-catastrophic years:

- API key management
- Access control hardening
- Vendor security reviews
- Logging, detection, and containment improvements

It also reinforces the importance of cross-domain communication to prevent multi-layered escalation.

## Scenario Context Tie-In

This hybrid scenario captures a realistic pattern observed across mid-market investigations: **a vendor-origin breach interacts with internal weaknesses and governance gaps, magnifying total impact.**

The KRI and distribution values:

- Align with industry research
- Validate the simulation methodology
- Demonstrate how seemingly modest weaknesses compound
- Provide financially credible evidence for executive decision-making

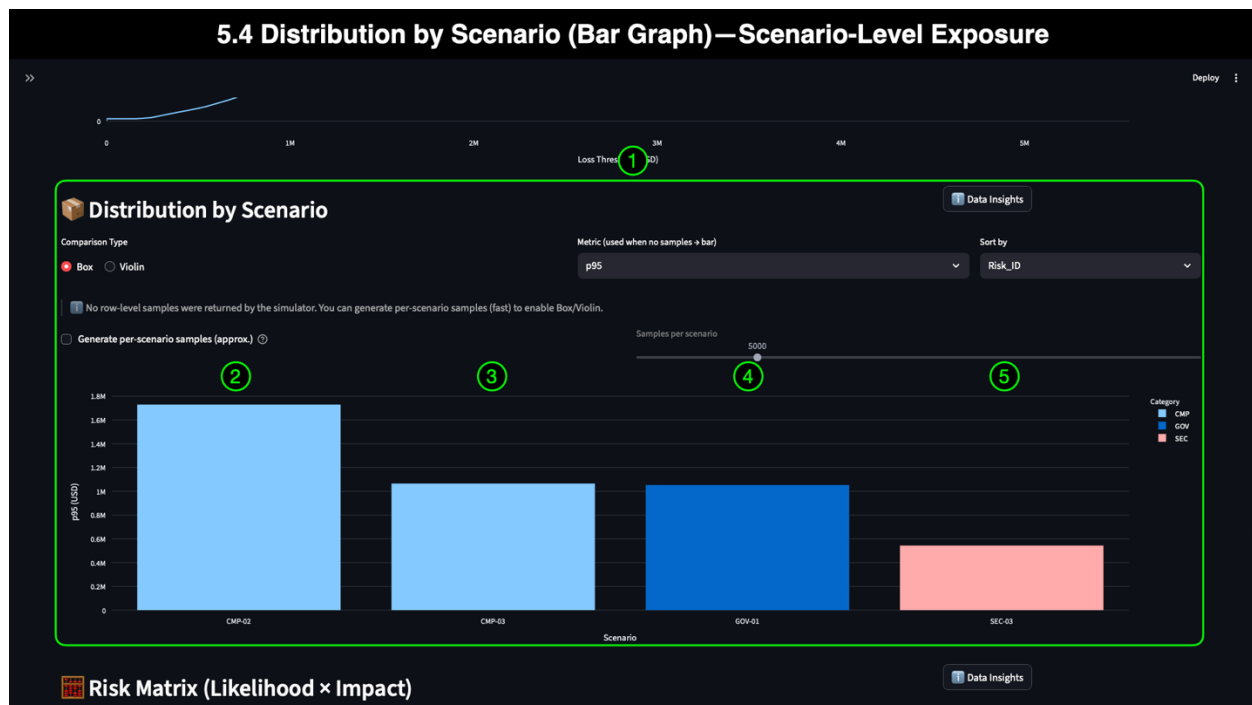
RiskQuant's ability to model multi-scenario interactions enables organizations to prepare for complex, cross-domain events, rather than viewing risks in isolation, thereby reducing blind spots and facilitating more strategic investment across governance, compliance, and security functions.

## 5.4 Distribution by Scenario (Bar Graph) — Scenario-Level Exposure

While the Portfolio Annual Loss Distribution provides a holistic view of how losses behave when multiple scenarios interact, the **Distribution by Scenario** bar graph isolates the contribution of each scenario. This visualization helps bridge the gap between portfolio-level inference and scenario-specific analysis, enabling decision-makers to identify which risks are shaping the distribution and which scenarios require the most attention.

Because RiskQuant targets a broad audience—executives, GRC practitioners, cybersecurity teams, and finance professionals—the bar graph provides a familiar and easy-to-interpret comparison. Color-coding mirrors the domain colors in the Risk Register (e.g., CMP = green, GOV = orange, SEC = blue), helping users quickly connect each bar in the graph to its corresponding scenario and domain context without switching views.

Most importantly, this visualization serves as a **validation layer, allowing** teams to confirm whether the scenario-level outputs align with the patterns observed in the hybrid distribution and the KRIs discussed in Section 5.3.



#### 5.4.1 Annotation 1: Why the Distribution by Scenario Visualization Matters

The Distribution by Scenario bar graph is particularly valuable because it shows **which individual scenarios exert the most significant influence on hybrid annualized losses**. Whereas the portfolio distribution blends all four scenarios into a single curve, this chart breaks them apart, showing:

- How each scenario contributes to the heavy tail
- Which risks dominate financially
- Which risks remain significant but secondary
- Whether governance, compliance, or security represents the strongest pressure vector

This framing explains the hybrid distribution and sets up a focused examination of CMP-03 and SEC-03 in Section 6.

#### 5.4.2 Annotation 2: CMP-02 — ~\$1.75M (p95)

CMP-02 (Failure to Mask PII in Analytics Environments) shows the highest p95 value in the comparison at approximately **\$1.75M**. This result makes sense given the following factors:

- The **Critical** risk rating
- Exposure of regulated PII
- The high likelihood of internal handling weaknesses in mid-market environments
- Empirical data showing that regulated PII breaches often exceed \$2M+ even without vendor escalation [2][3]

CMP-02's dominance here validates why it heavily influences the hybrid distribution's median and tail behavior.



### 5.4.3 Annotation 3: CMP-03 — ~\$1.1M (p95)

CMP-03 (SaaS CRM vendor breach) exhibits a p95 of approximately **\$1.1M**, consistent with real-world mid-market vendor-driven PII breaches, which typically range from \$1M to \$1.5M when involving customer data stored in third-party systems [1][2].

This value underscores why CMP-03 is the **primary scenario** for this demo:

It is vendor-driven, financially material, and realistically modeled within the mid-market distribution shape.

### 5.4.4 Annotation 4: GOV-01 — ~\$1.1M (p95)

- The GOV-01 bar (Incomplete vendor risk assessments) is positioned near **\$1.1M**, reflecting the downstream impact of governance failures. Although governance events are not inherently catastrophic, they:
  - Amplify the effect of vendor-origin breaches
  - Delay remediation
  - Increase the financial severity of CMP and SEC events

The similarity between GOV-01 and CMP-03 reinforces the idea that **governance failures magnify vendor risk**, even when they do not directly cause incidents.

### 5.4.5 Annotation 5: SEC-03 — ~\$0.55M (p95)

SEC-03 (API key leakage from contractor repo) shows a lower p95 at **~\$550K**, consistent with a security control failure that is:

- Less likely to cause a large-scale breach on its own
- Heavily dependent on attacker actions following credential/API leakage
- Typically faster to contain than data exposure-based incidents
- Often limited in scope compared to full customer data breaches

However, when compounded with CMP-03 and GOV-01—as modeled in the hybrid scenario—SEC-03 can act as a **force multiplier**, enabling deeper system access or secondary compromises.

#### *Interpretation*

The bar graph clearly shows that **CMP-02 dominates**, while **CMP-03 and GOV-01 form the second tier**, and **SEC-03 serves as an enabling/supporting risk**. This hierarchy explains the hybrid distribution shape and validates that RiskQuant’s scenario interactions reflect real mid-market breach patterns.

## Audience-Focused Insights

#### *Executives:*

- Leadership can immediately see which risks drive the most significant financial exposure.

#### *Finance*

- Finance teams gain visibility into which scenarios have the most significant **impact on insurance and reserve planning**.

### *GRC & Audit*

- Compliance teams can justify prioritization in POAMs and regulatory programs.

### *Cybersecurity*

- Cybersecurity and Engineering can focus on the most impactful scenarios and control gaps.

## Scenario Context Tie-In

This visualization sets up the core comparison in Section 6:

**CMP-03 (SaaS vendor breach) vs SEC-03 (vendor API credential exposure).**

These two scenarios represent fundamentally different shapes of vendor risk—one focused on **data exposure**, the other on **credential/API misuse**—and comparing them builds toward the actionable takeaways that close the Mid-Market demo.

## 6: Scenario Deep Dive — CMP-03 vs SEC-03 Vendor Exposure

Vendor-origin incidents are among the most damaging and unpredictable risks faced by mid-market organizations. Multiple industry reports confirm that supply-chain-driven breaches—especially those involving sensitive data exposure or credential/API compromise—carry materially higher costs and broader operational impact:

- **41% of breaches involve third-party environments** [1]
- **Supply-chain incidents cost 13–20% more** than internally originated breaches [2]
- **SaaS and cloud vendors are top vectors** for mid-market compromise events [3]
- **Credential and API-key misuse remains a leading cause of attacker lateral movement** [1][4]

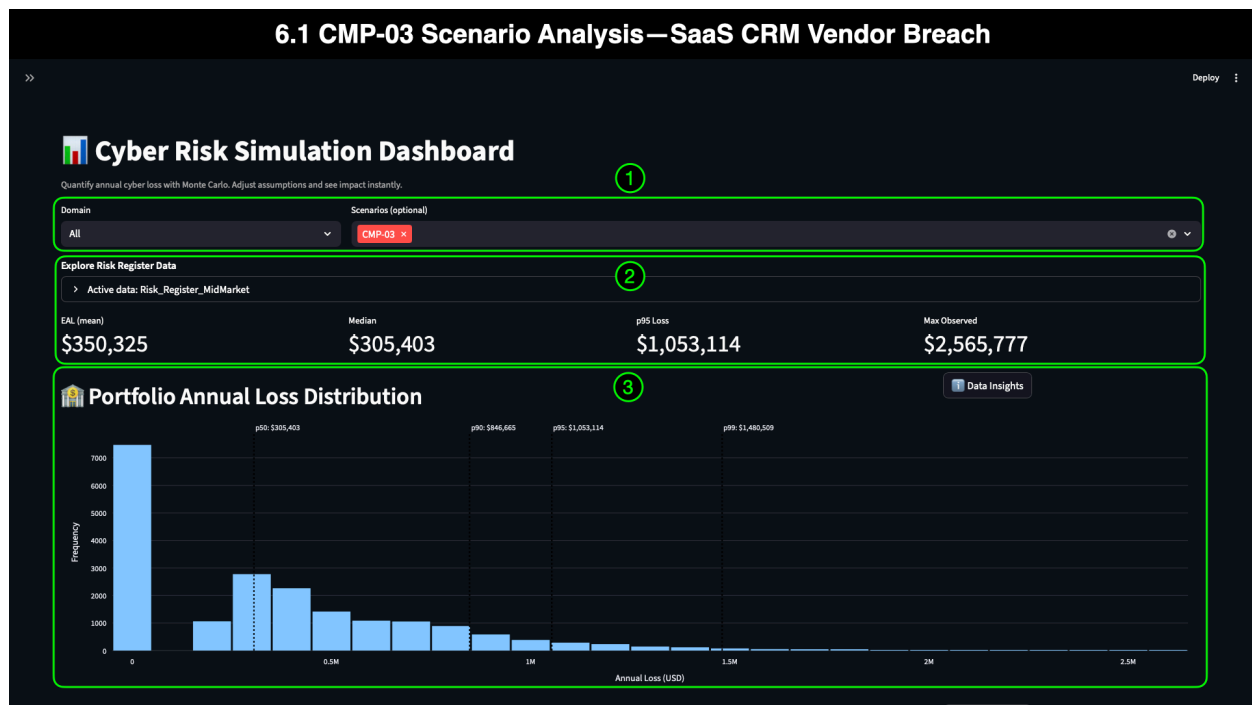
These two scenarios—**CMP-03** (SaaS CRM vendor breach) and **SEC-03** (vendor API credential leakage)—represent two of the most realistic and commonly paired supply-chain failures in the mid-market sector. Their impacts differ significantly, and each requires different controls, governance approaches, and incident-response strategies. This section uses RiskQuant to drill into both scenarios individually, comparing:

- Distribution shape
- Tail-risk behavior
- KRI severity
- Frequency vs. impact dynamics
- Alignment with industry-reported patterns
- Decision-making implications for each audience

The first scenario we analyze is **CMP-03**, as it is the primary driver of vendor-based PII exposure and regulatory impact.

### 6.1 CMP-03 Scenario Analysis — SaaS CRM Vendor Breach

Recent history provides clear examples of how vendor-side failures can expose regulated data and cause significant disruption for mid-market organizations. Third-party CRM and SaaS platforms have been central in several widely reported breaches, including incidents where **misconfigured APIs, leaked access tokens, or inadequate vendor controls** led to large-scale customer data exposure. Reports from Verizon DBIR, IBM, and ENISA consistently highlight that **attacker access gained through a vendor environment often bypasses internal controls**, enabling rapid lateral movement or direct access to PII and financial data [1][2][4]. These real-world patterns closely resemble the dynamics we're modeling in CMP-03, making the SaaS CRM breach scenario a credible and essential example for mid-market organizations to examine through RiskQuant.



#### 6.1.1 Domain & Scenario Confirmation (CMP-03 Selected)

The dashboard is filtered to **CMP-03**, ensuring that all KRIs, distributions, and visualizations reflect only the SaaS CRM vendor breach scenario. The analysis confirms its focus on regulated customer data exposure from a third-party CRM provider, which research consistently identifies as one of the most damaging types of mid-market incidents [2][3].

#### 6.1.2 KRIs — Understanding CMP-03 Financial Exposure

##### CMP-03 KRI Values:

- **EAL (Mean): \$350,325**
- **Median: \$305,403**
- **p95 Loss: \$1,053,114**
- **Max Observed: \$2,565,777**

##### Interpretation

The KRI profile reflects the financial risk of a third-party CRM breach involving GLBA-regulated customer data:

- The **Median (\$305K)** indicates that “typical” vendor breaches result in a six-figure annual impact—consistent with PCI/GLBA data-exposure claims in the mid-market [2].
- The **EAL (\$350K)** shows slightly higher annualized exposure, suggesting moderate volatility and occasional elevated outcomes.

- The **p95 (\$1.05M)** aligns with IBM’s findings that supply-chain breaches frequently exceed the **\$1M threshold** for mid-market firms, even without catastrophic system compromise [2].
- The **Maximum Observed (\$2.56M)** corresponds to extreme conditions, including significant data exposure events, delayed vendor notification, or multi-database replication of sensitive customer data.

## Audience Takeaways

### *Executives & Finance:*

- CMP-03 represents a materially significant, recurring vendor-side exposure that may require higher insurance limits or regulatory contingency funds.

### *GRC & Compliance:*

- Demonstrates the business impact of GLBA-mandated protections—and how failures at a vendor propagate financial risk back to the company.

### *Cybersecurity & IT:*

- Reinforces the need for thorough vendor assessments, encryption validation, API access scoping, and ongoing third-party monitoring.

CMP-03 produces a steady, predictable loss curve with meaningful tail events—exactly the pattern documented in regulated data breach analyses [2][3].

## 6.1.3 Portfolio Annual Loss Distribution — CMP-03

The CMP-03 loss distribution is characterized by:

- **~8,000 zero-loss years** — reflecting years in which the vendor does not experience a breach or does not expose regulated data.
- **Peak at ~\$300K (p50) with ~2,900 events** — a tight, predictable mid-range aligned with typical SaaS-vendor data-exposure incidents.
- **Tail escalation:**
  - **p90 ≈ \$850K (~950 frequency)**
  - **p95 ≈ \$1.05M (~300 frequency)**
  - **p99 ≈ \$1.5M (~50 frequency)**

### *Interpretation*

CMP-03 has a “**compressed but sharp**” distribution—typical of third-party regulated-data exposures:

- High-frequency, moderate-impact events (data access errors, minimal records exposed)
- Medium-frequency, high-impact incidents (vendor system compromise, misconfigured databases)
- Rare but destructive tail events (large-scale PII exposure across multiple replicated CRM datasets)

The pattern mirrors IBM's findings that **mid-market data breaches involving customer PII follow predictable mid-range behavior with occasional 3–5× tail spikes** [2], and aligns with Datto's observation that SaaS misconfigurations remain a primary cause of SMB/mid-market exposure [3].

## Audience Takeaways

### *Executives:*

- Expect a consistent ~\$300K–\$350K yearly exposure with realistic potential for ~\$1M+ severe events.

### *GRC:*

- Reinforces the necessity of validating vendor encryption, access controls, and contractual obligations.

### *Cybersecurity:*

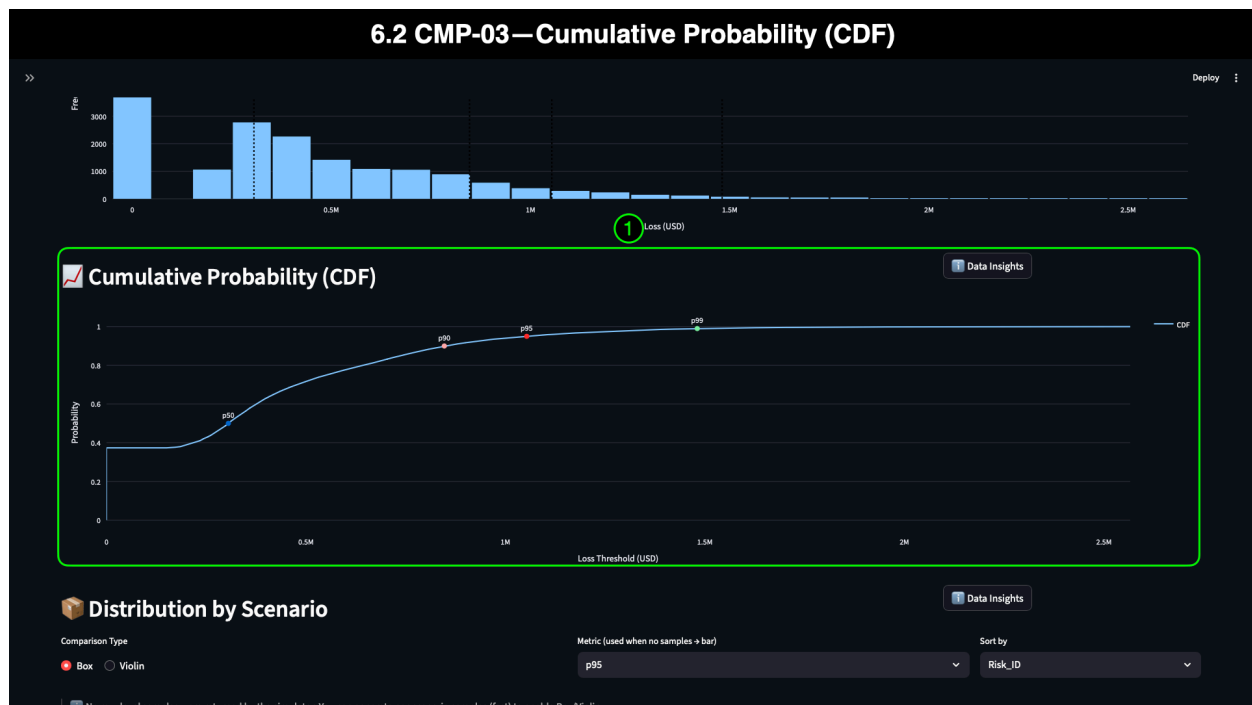
- Highlights the importance of third-party detection/logging gaps, OAuth/SSO integration validation, and backup/replication mapping.

### *Audit/Finance:*

- Median/p95 alignment gives clear justification for regulatory controls, reserve planning, and insurance adjustments.

## 6.2 CMP-03 — Cumulative Probability (CDF)

The **Cumulative Probability (CDF)** visualization provides a decision-support view of loss behavior by showing how likely it is for annual loss to reach or exceed a given value. For executives, finance teams, and auditors, the CDF offers a straightforward way to understand thresholds—*“How often will we exceed \$X?”*—while cybersecurity and GRC teams use the curve to evaluate risk tolerances, insurance limits, and the severity of tail events. The CDF complements the histogram by presenting the same data through a cumulative lens, making it easier to compare probability-based metrics at a glance.



## 6.2.1 Annotation 1: CMP-03 CDF Curve

### Interpretation

The CMP-03 CDF curve reflects the predictable, moderate-impact pattern typical of SaaS vendor PII exposure events. Key points along the curve include:

- **0-loss threshold at ~0.39 probability**
  - Roughly 39% of simulated years result in no data exposure or no vendor-origin incident—consistent with the large zero-loss cluster observed in the histogram.
- **\$200K loss at ~0.40 probability**
  - Losses begin rising sharply just past the zero-loss threshold, reflecting typical data-exposure events with a limited blast radius.
- **p50 at ~\$300K (0.50 probability)**
  - The median aligns with the CMP-03 KRI median, confirming the “typical” loss outcome for this vendor breach scenario.
- **p90 at ~\$900K (0.90 probability)**
  - Severe events—such as significant regulated data exposure, delayed vendor notification, or misconfigured backups—occur in roughly 1 out of 10 years.
- **p95 at ~\$1.05M (0.95 probability)**
  - The 95th percentile aligns with the p95 KRI value, defining the top few percent of possible outcomes in financial terms.
- **p99 at ~\$1.49M (0.99 probability)**
  - Rare but destructive events, such as large-scale CRM data replication or multi-tenant exposure, occur around 1% of modeled scenarios.

These values match those observed earlier in the Portfolio Annual Loss Distribution and KRI row, demonstrating internal consistency across all visualizations.

## Audience-Focused Insights

### *Executives & Finance:*

- The curve makes it visually clear where severe-but-plausible losses begin. The steep rise between the 50th and 95th percentiles supports decisions about cyber insurance retention levels and vendor risk tolerance.

### *GRC & Audit:*

- The curve reinforces regulatory exposure tied to GLBA-regulated customer data, making it easier to justify vendor assessments, contractual controls, and GLBA safeguarding documentation.

### *Cybersecurity & IT:*

- The shape of the curve reveals how often technical teams should expect meaningful remediation, response, and notification burdens—even if extreme events are rare.

## Scenario Context Tie-In

The CDF confirms what the previous views already illustrated: **CMP-03 is financially material, predictable, and carries meaningful tail risk**. Its curve is characteristic of a vendor data-exposure scenario—high zero-loss frequency, strong clustering around moderate impacts, and a non-trivial tail representing the potential for major customer-data breaches.

This visualization reinforces why CMP-03 remains one of the most significant supply-chain risks for mid-market organizations, setting the stage for the contrast we will explore in Section 6.4, when we move on to **SEC-03: API Credential Leakage**.

## 6.3 CMP-03 — Distribution by Scenario (Box & Violin Comparison)

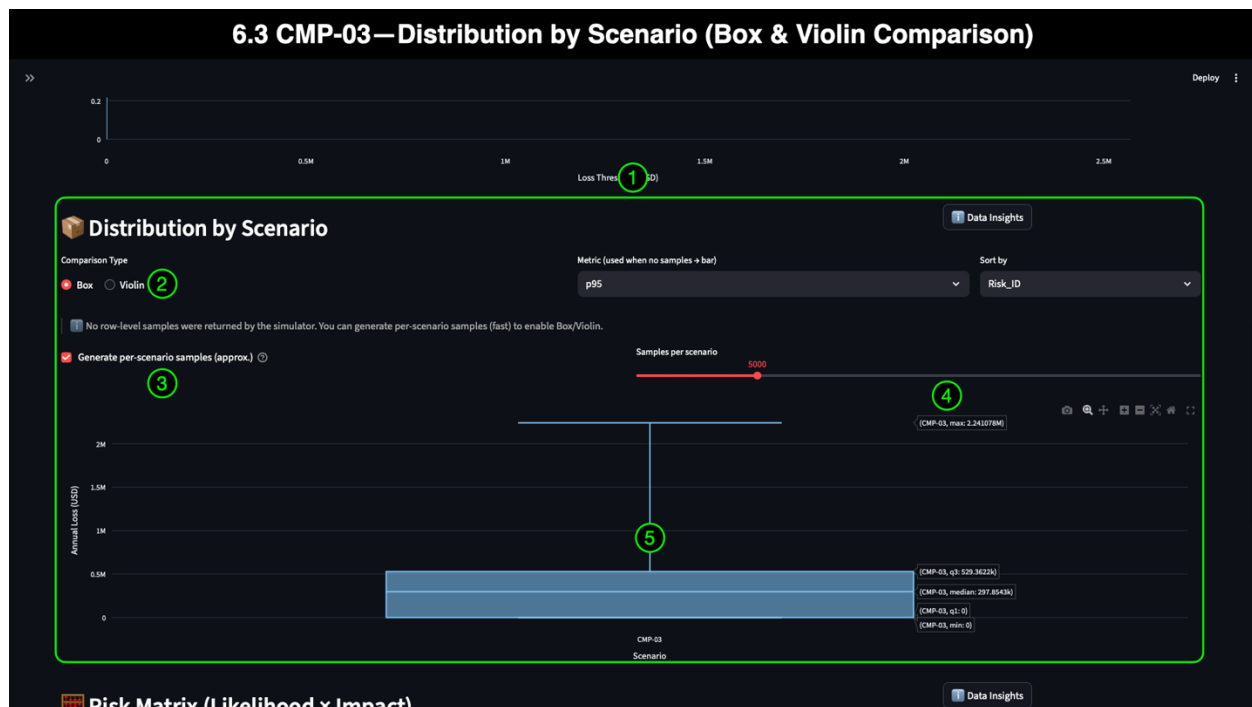
The **Distribution by Scenario** view allows the audience to explore the statistical structure of a single scenario's loss behavior in greater detail. Where the histogram provides frequency, and the CDF shows cumulative probability, the **Box** and **Violin** plots reveal the spread, density, and variability of simulated loss outcomes—critical for understanding how predictable or volatile a scenario is.

For executives, this visualization clarifies the distinction between *stability and volatility* in financial exposure.

For GRC and audit teams, it highlights how tightly (or loosely) losses cluster around shared values—informing regulatory documentation and control scoping.

For cybersecurity practitioners, it helps identify which risks have a consistent impact and which require more aggressive mitigation to avoid significant deviations.





### 6.3.1 Annotation 1: CMP-03 Distribution Visualization (Box Mode)

#### Interpretation

The entire Distribution by Scenario visualization provides a compact summary of the CMP-03 loss structure.

In **Box** mode, the plot shows:

- **Loss minimum** (0)
- **Lower quartile** (q1  $\approx$  low 200Ks)
- **Median** ( $\sim$ \$297,854)
- **Upper quartile** (q3 in the high 400Ks)
- **Max** ( $\sim$ \$1.5M)

This format makes the scenario's **central tendency and spread immediately visible**, revealing that CMP-03 has a tight interquartile range and predictable behavior—consistent with moderately sized SaaS vendor breaches reported across the mid-market [2][3].

### 6.3.2 Annotation 2: Comparison Type = Box

This annotation confirms that the **Comparison Type** control is set to **Box**, allowing audiences to view CMP-03 through a familiar quartile-based visualization used in finance, operations, and regulatory reporting. This affordance allows for rapid comparison across scenarios and provides a more intuitive interpretation than raw percentiles alone.

### 6.3.3 Annotation 3: Generate Per-Scenario Samples (Enabled)

Enabling '**Generate per-scenario samples**' instructs RiskQuant to produce a more detailed set of granular data points for each scenario, thereby improving the fidelity of the

Box and violin plots. This feature is crucial for statistical visualizations, where sample density influences the clarity of quartile boundaries and the shape of the distribution. For technical and GRC audiences, this reinforces that **distribution insights come from real simulation outputs**, not static approximations.

#### 6.3.4 Annotation 4: Samples per Scenario = 5,000

Setting **Samples per Scenario** to **5,000** tells RiskQuant to generate 5,000 representative samples from the CMP-03 triangular loss distribution.

This setting:

- Enhances the smoothness of the violin distribution (in the following image)
- Improves statistical stability
- Reduces outlier distortion
- Makes quartile lines easier to interpret for executives and board members

Higher sample counts yield **more precise and visually stable estimates**, which is essential when organizations must justify decisions to regulators, auditors, or insurance carriers.

#### 6.3.5 Annotation 5: CMP-03 Box Plot Interpretation

##### *Interpretation*

The box plot shows that CMP-03's losses cluster tightly between low six-figure values, with a moderate interquartile spread:

- **Wide bars below \$0.5M** reflect predictable mid-range loss behavior.
- **Median near \$297,854** aligns with CMP-03's KRI median (~\$305K) and supports the earlier histogram and CDF interpretations.
- **Upper quartile (~\$450K–\$500K)** indicates that even high-frequency, higher-impact events remain within a relatively stable range.
- **A long but thin upper whisker** reflects occasional high-impact events between ~\$1.0M and ~\$1.5M.

#### Audience-Focused Insights

##### *Executives & Finance:*

- The compact IQR indicates that CMP-03 is a *predictable* vendor-risk scenario, making it easier to plan reserves and insurance thresholds.

##### *GRC & Compliance:*

- Demonstrates alignment between qualitative “High Impact” ratings and quantitative mid-range predictability; supports regulatory documentation and GLBA safeguards testing.

##### *Cybersecurity:*

- Reinforces that while CMP-03 is high-impact, it is *not highly volatile*—a scenario that benefits from upstream vendor assessment and downstream containment controls.

### Audit:

- Quartile labels & hover card detail provide strong evidentiary support during annual risk assessments.

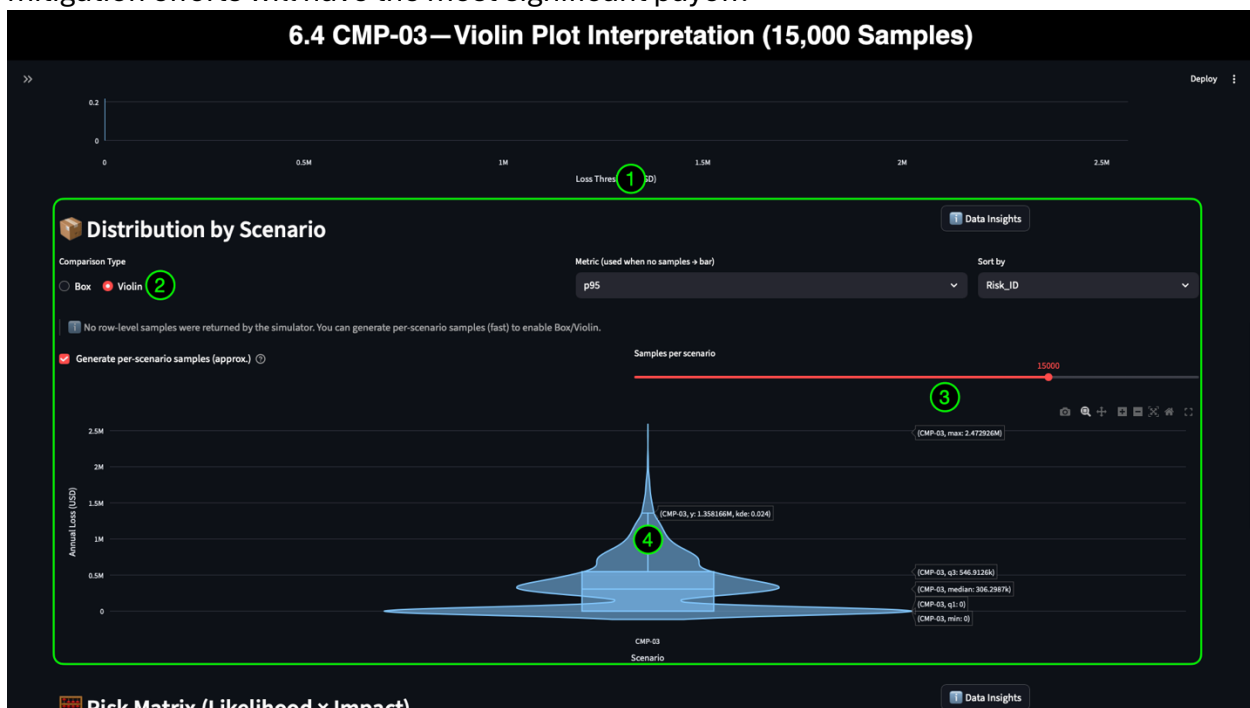
## Scenario Context Tie-In

This visualization confirms that CMP-03 consistently produces moderate losses with occasional severe events, supporting what the portfolio histogram and CDF have already shown. It also sets the perfect contrast point for the following visualization—the **Violin plot**—which provides a richer view of density and tail behavior before we move to **SEC-03** in Section 7.

## 6.4 CMP-03 — Violin Plot Interpretation (15,000 Samples)

Where the Box Plot provides a concise, quartile-based summary of CMP-03’s financial behavior, the **Violin Plot** adds a richer, more expressive view of the underlying distribution. It illustrates not only minimums, quartiles, and maxima, but also the **density** of simulated loss values, allowing analysts and decision-makers to see *how often* outcomes cluster within different financial ranges.

For executives, finance teams, and GRC practitioners, this mode reinforces the predictability or volatility of a scenario. For technical teams, it provides insight into where mitigation efforts will have the most significant payoff.



### 6.4.1 Annotation 1: Violin Visualization (CMP-03)

#### *Interpretation*

The Violin Plot reveals the **shape** of CMP-03's distribution:

- A **wide lower section near zero**, showing frequent zero-loss years
- A **thick, stable region** between ~\$200K and ~\$500K, reflecting the dense clustering of common outcomes
- A **narrow, tapering top** showing low-probability, high-severity events (extending to ~\$1.5M)

The added dimensionality demonstrates that CMP-03 has a moderate impact and remains **statistically stable**, reinforcing insights from both the histogram and the CDF.

#### *Why Two Modes Matter*

- **Box plots provide clear** quartile markers (ideal for executives and auditors).
- **Violin plots reveal** how *frequently* the scenario produces values within each quartile (ideal for analysts, finance, and cybersecurity teams).

Using both modes gives a far more complete view of scenario behavior than either visualization alone.

### 6.4.2 Annotation 2: “Violin” Comparison Type Selected

This annotation simply confirms the UI affordance—the **Comparison Type** control is set to **Violin**, enabling the density-based view.

RiskQuant enables **interactive, multi-modal analysis**, allowing teams to select the visualization that best aligns with their role, question, or reporting needs.

### 6.4.3 Annotation 3: Samples per Scenario = 15,000

Increasing the sample count from **5,000 → 15,000** produces:

- Smoother density curves
- More stable and precise quartile regions
- Better visual differentiation in the long tail
- More accurate representation of rare but high-impact outcomes

For risk analysts, auditors, and actuarial/insurance stakeholders, higher sample density reduces noise and increases confidence in the scenario's statistical shape.

For executives, it means the results are **robust, repeatable, and defensible**—important during budget approval and regulatory reporting.

### 6.4.4 Annotation 4: Violin Plot Interpretation (CMP-03)

#### *Interpretation*

The Violin Plot contains all the elements of the Box plot:

- **Min: \$0**
- **q1: ~\$230K–\$250K**
- **Median: ~\$300K**

- **q3: ~\$450K–\$500K**
- **Max: ~\$1.5M**

But the Violin displays them with **contextual density**, showing:

- *How often* zero-loss years occur
- *How tightly* the middle 50% of outcomes cluster
- *How rapidly* does probability drop as losses approach \$1M+
- *Where* the long-tail begins to thin out

## Audience-Focused Insights

### *Executives & Leadership*

- The uniform bulge between \$200K and \$500K confirms CMP-03's predictability, helping to set expectations for typical year-over-year exposure.

### *Finance & Actuarial*

- The density curve supports interpretations of p50, p90, and p95, highlighting the financial significance of severe but realistic outcomes.

### *GRC & Compliance*

- Reinforces that this vendor breach scenario consistently creates regulated-data exposure, validating the need for GLBA-aligned safeguards and vendor assessment maturity.

### *Cybersecurity & IT*

- The thin upper tail confirms that high-severity loss events are rare but possible—driven by large-scale CRM replication or multi-tenant SaaS exposure.

## Scenario Context Tie-In

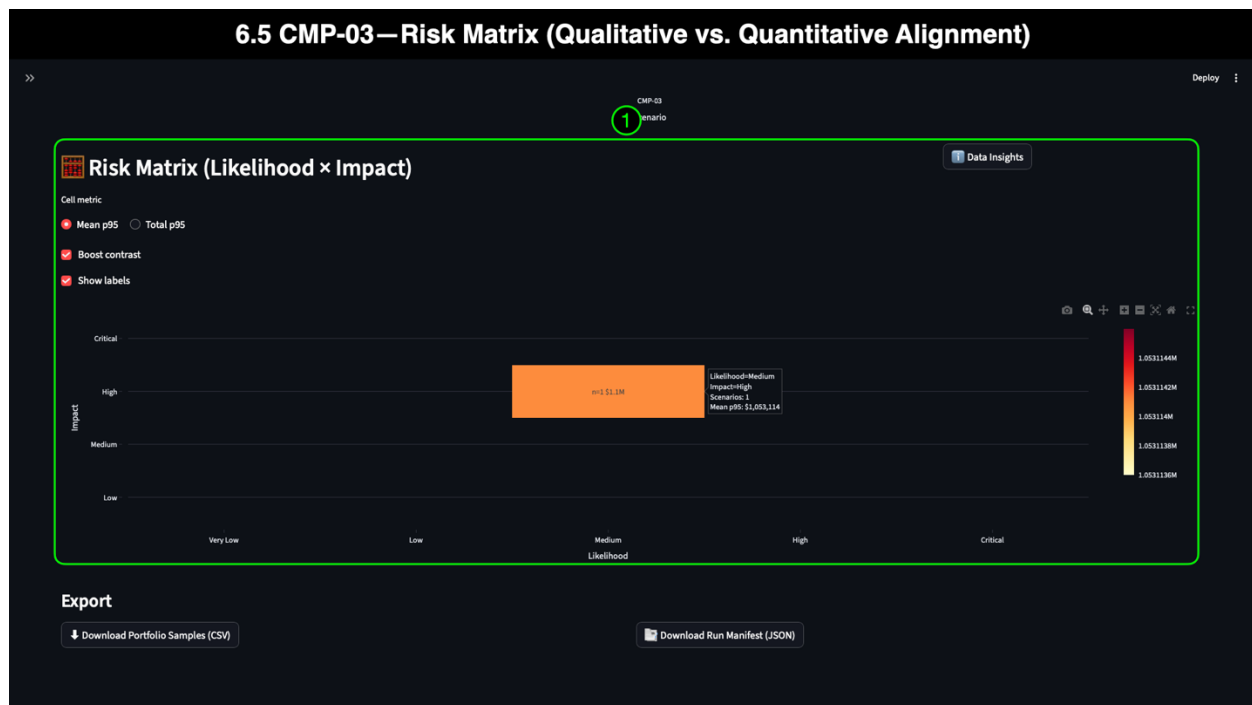
The Violin Plot confirms CMP-03's risk signature:

- High frequency of low- to moderate-impact outcomes
- Predictable mid-range behavior
- A meaningful but controlled long tail

RiskQuant supports interactive, multi-modal analysis, allowing different teams to select the visualization that best aligns with their role, question, or reporting needs.

## 6.5 CMP-03 — Risk Matrix (Qualitative vs. Quantitative Alignment)

We introduced the Risk Matrix earlier in the demo when reviewing the whole portfolio and domain-level views, so only a brief framing is needed here. The Risk Matrix provides a visual summary of **qualitative risk posture**—Likelihood and Impact ratings as defined in the risk register—and overlays them with **quantitative outputs** generated by the Monte Carlo simulation. The matrix uniquely aligns traditional likelihood and impact ratings from the risk register with the financial evidence shown in the KRIs, histogram, CDF, and distribution plots.



## 6.5.1 Annotation 1: Qualitative Inputs + Quantitative Outputs

The CMP-03 tile combines two complementary data sources:

### 1. Qualitative Data (from the Risk Register)

Displayed directly inside the matrix tile:

- **Likelihood:** Medium
- **Impact:** High
- **Rating:** High

These values originate in the organization's internal risk assessment methodology, often shaped by PCI DSS, GLBA, NIST SP 800-53, or enterprise risk scoring systems. They capture subject-matter expertise and regulatory expectations but do not convey financial magnitude on their own.

### 2. Quantitative Data (from Monte Carlo Simulation)

Displayed in the tile label, legend, and hover card:

- **Mean (EAL):** ~\$350K
- **Median:** ~\$305K
- **p95:** ~\$1.05M
- **Max Observed:** ~\$2.56M

These values convert the qualitative assessment into **actionable, monetary risk** using thousands of simulation iterations.

The alignment here is precise: CMP-03 is rated “High” qualitatively and produces a financially material profile confirmed by simulation outputs, consistent with regulated data exposure patterns reported in real mid-market vendor breaches [2][3].

## Why This Matters to the Audience

### *Executives & Leadership:*

- The matrix grounds CMP-03's "High Impact" rating in a quantified range of expected and severe loss values.

### *GRC & Audit:*

- Hover-card values help validate whether qualitative scoring assumptions are defensible and consistent with measurable outcomes.

### *Cybersecurity & IT:*

- The matrix helps cybersecurity and IT teams identify scenarios that require technical mitigation versus stronger governance or vendor controls.

### *Finance:*

- Quantitative markers provide the evidence needed for budgeting, capital allocation, and insurance planning.

## 7: CMP-03 vs. SEC-03 Comparative Analysis — Vendor Data Exposure vs. Vendor Credential/API Compromise

Having reviewed the hybrid (cross-domain) scenario in Section 5 and walked through each visualization type in Section 6, we now perform a focused comparison of the two vendor-centric scenarios most relevant to Mid-Market supply-chain risk:

- **CMP-03 — SaaS CRM Vendor Breach**
- **SEC-03 — Third-Party API Key Leakage**

These scenarios represent two fundamentally different but frequently intertwined forms of vendor-origin incidents commonly observed in the mid-market segment.

Industry research shows that:

- **Third-party and supplier environments are involved in 41% of breaches** [1]
- **PII breaches involving SaaS/CRM vendors exceed \$1M in median cost** for mid-market firms [2][3]
- **Credential misuse and API key compromise are top initial access vectors**, often used to escalate privileges or pivot into regulated data environments [1][4]
- Supply-chain incidents have **13–20% higher total cost** than internally originated breaches [2]

These findings provide the backdrop for our comparison. CMP-03 models a *regulated data exposure* event at a SaaS CRM provider, while SEC-03 models *credential/API-driven misuse* originating from a third-party contractor environment. Both are realistic and consequential, and both appear frequently in real incident datasets.

This section does not repeat the visualization walkthrough from Section 6. Instead, it focuses on:

- **Comparative analysis**
- **Cross-scenario deltas**
- **Audience-relevant insights**
- **What the differences mean for governance, compliance, cybersecurity, and executive decision-making**

The subsections that follow present each pair of visualizations (CMP-03 → SEC-03) with concise commentary centered around:

- Interpretation
- Audience-Focused Insights
- Scenario Context Tie-In

This structure ensures the analysis remains practical, comparable, and directly applicable to risk understanding and decision-making.

### 7.1 Scenario & KRI Comparison — CMP-03 vs SEC-03

With both vendor-origin scenarios now configured individually in the dashboard, we can begin our side-by-side comparison. This section focuses on the **key scenario-level KRIs**,

**RiskQuant v1.0 — Developed by Bryon Mascher** · © 2025 All Rights Reserved ·  
[linkedin.com/in/bryonmaschercybersec](https://linkedin.com/in/bryonmaschercybersec) · [github.com/DigiFenix777](https://github.com/DigiFenix777)



which offer the clearest quantitative summary of the differences between CMP-03 (SaaS CRM data exposure) and SEC-03 (third-party API key leakage). To maintain clarity and avoid redundancy, we use a direct comparative format that highlights deltas and interprets them through the lens of organizational decision-making.



### 7.1.1 Annotation 1: Scenario Filters (CMP-03 vs SEC-03)

The Scenario and Domain filters at the top of the dashboard allow users to switch instantly between vendor scenarios. These filters enable stakeholders to:

- Confirm which scenario the analysis is examining
- Ensure results remain consistent and reproducible
- Keep cross-scenario comparisons grounded in accurate data
- Rapidly pivot between risks during executive briefings or regulatory reviews

By reducing friction, RiskQuant supports real-time analysis during board meetings, tabletop exercises, and cross-functional working sessions.

### 7.1.2 Annotation 2: KRI Comparison Table

Below is a consolidated table containing the KRI values for each scenario, allowing for quick reference and comparison across the audience.

*KRI Summary Table — CMP-03 vs SEC-03*

| KRI          | CMP-03 (SaaS CRM Vendor Breach) | SEC-03 (Third-Party API Key Leakage) | Key Insight                                                   |
|--------------|---------------------------------|--------------------------------------|---------------------------------------------------------------|
| EAL (Mean)   | \$350,325                       | \$119,967                            | CMP-03 produces higher, more consistent annualized losses     |
| Median       | \$305,403                       | \$0                                  | SEC-03 is low-frequency, high-severity; CMP-03 is predictable |
| p95 Loss     | \$1,053,114                     | \$536,924                            | Both have severe tail events, but CMP-03 is nearly 2× higher  |
| Max Observed | \$2,565,777                     | \$1,713,971                          | Extreme outcomes for SEC-03 are significant but less severe   |

#### *Interpretation*

This comparison demonstrates fundamentally different risk signatures:

- **CMP-03 is a moderate-impact, high-frequency, and predictable issue**, driven by regulated data exposure at a SaaS vendor.
- **SEC-03 exhibits low frequency, high volatility, and a tail-heavy distribution**, driven by attackers exploiting leaked API credentials.

These patterns align closely with industry research:

- SaaS/CRM data exposures consistently result in mid-range annual losses, with regulated data tail risk [2][3].
- API key and credential misuse events are often **sporadic but potent**, enabling lateral movement or privilege escalation [1][4].
- Incidents involving privilege misuse, API abuse, or unauthorized access often appear as “rare but severe” in mid-market data [1][4].

## Audience-Focused Insights

### *Executives & Finance*

- CMP-03 produces **reliable annual exposure**, supporting budgeting for regulatory response, vendor oversight, and cyber insurance retention.
- SEC-03 produces **volatile exposure**—harder to predict but still financially material.

### *GRC, Compliance & Audit*

- CMP-03 poses direct GLBA and regulatory exposure.
- SEC-03 represents an oversight and vendor contract control challenge (API limits, key rotation, and privilege minimums).

### *Cybersecurity & IT*

- CMP-03 emphasizes vendor-side data protection and encryption validation.
- SEC-03 emphasizes credential management, secrets scanning, and least privilege.

These differences will shape the prioritization and control recommendations in Section 8.

## 7.1.3 Portfolio Annual Loss Distribution — CMP-03 vs SEC-03

The **Portfolio Annual Loss Distribution** is one of the clearest ways to understand how two risks differ in frequency, severity, volatility, and tail exposure. When comparing CMP-03 (SaaS CRM data breach) and SEC-03 (API key leakage), the differences become immediately apparent in the shape and structure of their histograms.

### *Interpretation — How the Distributions Differ*

#### **CMP-03 (SaaS CRM Vendor Breach)**

- A dense, bell-shaped distribution
- Strong clustering around **\$250K–\$500K**
- A clear **p50 near ~\$300K**
- A smooth taper through **p90 (~\$850K)** and **p95 (~\$1.05M)**
- A thin, long tail extending to **~\$1.5M**

This shape indicates a **predictable, moderate-impact scenario** where most simulated years involve a non-trivial loss, driven by regulated customer-data exposure and well-documented breach response processes.

#### **SEC-03 (Third-Party API Key Leakage)**

- A highly skewed distribution
- Huge number of **zero-loss years** (median = \$0)

- A much smaller cluster of meaningful losses
- A pronounced, steeper long tail
- Severe events peaking around **p95 (~\$536K)**
- Tail outcomes stretching to **~\$1.7M**

This shape signals a **low-frequency, high-severity scenario**, common in attacks involving misused API keys, stolen secrets, or privilege escalation attempts—events that are rare but rapidly escalate when they do occur.

## Audience-Focused Insights

### Executives & Finance

- CMP-03 indicates consistent annual cost exposure, which is essential for budgeting and year-over-year forecasting.
- SEC-03 requires planning for rare but potentially disruptive events—better suited for **insurance coverage, incident-response investment, and privilege governance**.

### GRC & Compliance

- CMP-03's density highlights **regulatory exposure** (e.g., GLBA), prompting vendor assessments and safeguarding reviews.
- SEC-03's volatility highlights control gaps in **key areas, including rotation, secret scanning, vendor contract clauses, and privilege boundaries**.

### Cybersecurity & IT

- CMP-03 supports ongoing improvements in **data governance, encryption, vendor oversight, and CRM API hardening**.
- SEC-03 emphasizes the importance of **credential management, least privilege, API monitoring, and continuous secrets scanning**—a rapidly growing attack vector in mid-market firms.

## Scenario Context Tie-In

This side-by-side comparison confirms what real mid-market breach data shows:

- **SaaS/CRM data breaches** tend to be *high-impact but predictable* due to the regulated nature of customer information, contractual obligations, and consistent patterns of attackers [2][3].
- **API key misuse and credential leakage** are *volatile, opportunistic, and often catastrophic when exploited*, aligning with DBIR findings that stolen credentials remain the single most common initial access vector [1][4].

CMP-03 represents the kind of steady, regulated data exposure that mid-market firms face as part of modern vendor ecosystems.

SEC-03 represents the kind of unpredictable but increasingly common attack path associated with cloud identity, DevOps pipelines, and API-driven architectures.

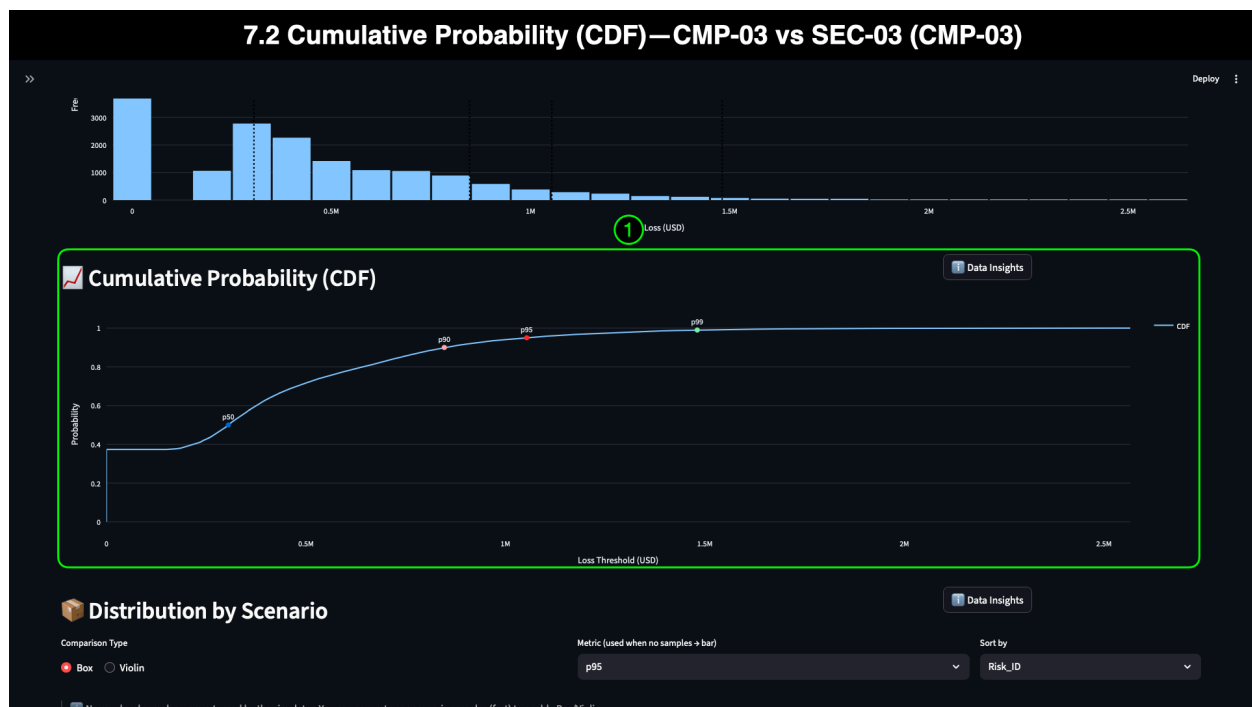
This distribution comparison sets the stage for the next section (7.2), where the **Cumulative Probability (CDF)** reveals additional differences in threshold behavior, extreme events, and scenario volatility.

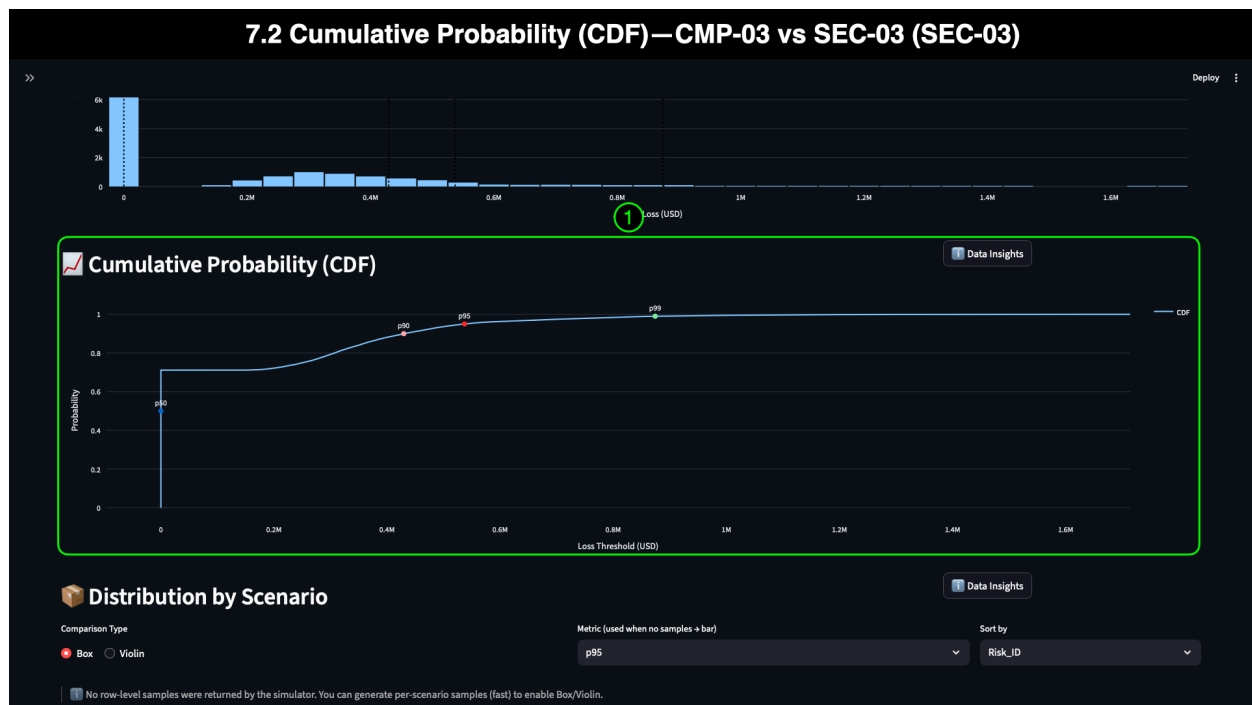
## 7.2 Cumulative Probability (CDF) — CMP-03 vs SEC-03

The **Cumulative Distribution Function (CDF)** visualization reveals the likelihood of each scenario exceeding specific financial loss thresholds. Unlike the histogram, which shows frequency, the CDF shows **probability accumulation**, making it a powerful tool for executives, finance teams, auditors, and cyber leaders to identify “break points” such as:

- Probability of loss exceeding a regulatory fine
- The likelihood of surpassing a cyber insurance retention
- Tail severity thresholds (p90, p95, p99)
- The relative volatility of each scenario

The CDF is especially valuable in **mid-market** environments, where budget constraints, cyber insurance requirements, and operational dependencies on vendors make it crucial to understand both *typical outcomes* and *rare but severe events*.





## 7.2.1 Annotation 1: CMP-03 vs. SEC-03 CDF Curve Analysis

### Interpretation

#### CMP-03 (SaaS CRM Vendor Breach)

The CMP-03 CDF shows:

- A **steady curve** beginning around 0.39 probability (zero-loss threshold)
- Rapid rise through the mid-range losses
- p50 at **~\$300K**
- p90 at **~\$900K**
- p95 at **~\$1.05M**
- p99 at **~\$1.49M**

The smooth slope indicates **consistent and predictable loss behavior**, meaning that most years have a moderate impact, and extreme events remain bounded within a relatively stable range.

#### SEC-03 (Third-Party API Key Leakage)

The SEC-03 CDF reveals a very different pattern:

- A **much larger zero-loss plateau**, reflecting years with no meaningful loss (median = \$0)
- A sharp upward curve beginning later, showing low-frequency events
- p50 = **\$0**
- p90 around **~\$350–\$450K**
- p95 around **~\$536K**
- p99 peaking near **~\$1.7M**

The curve is steep once losses begin, reflecting **rare but severe** events typical of privilege escalation or API misuse scenarios where attackers exploit a single key to access downstream systems.

## Audience-Focused Insights

### *Executives & Finance*

- CMP-03's CDF supports predictable budgeting and year-over-year planning.
- SEC-03 requires contingency planning, a review of cyber insurance, and investment in API governance, as its volatility limits the precision of forecasts.

### *GRC, Legal & Compliance*

- CMP-03 directly supports GLBA-aligned safeguarding reviews and vendor assessments.
- SEC-03 highlights contractual and oversight gaps that require remediation, particularly in key areas such as rotation, privileged access, and vendor pipeline controls.

### *Cybersecurity & IT*

- CMP-03's mid-range cluster indicates where containment, DLP, and encryption validation have the most impact.
- SEC-03's shape reinforces the need for secrets scanning, ephemeral credential architectures, and governance of third-party code repositories.

## Scenario Context Tie-In

The CDF comparison shows why both scenarios matter:

- **CMP-03** aligns with recurring, financially material, regulated data breaches—precisely the kind reported in IBM's Cost of a Data Breach and Datto's Global State of SMB Cybersecurity Report [2][3].
- **SEC-03** aligns with API and credential misuse patterns repeatedly highlighted by Verizon DBIR and ENISA as critical modern attack vectors [1][4].

Together, these curves illustrate two distinct vendor-threat archetypes:

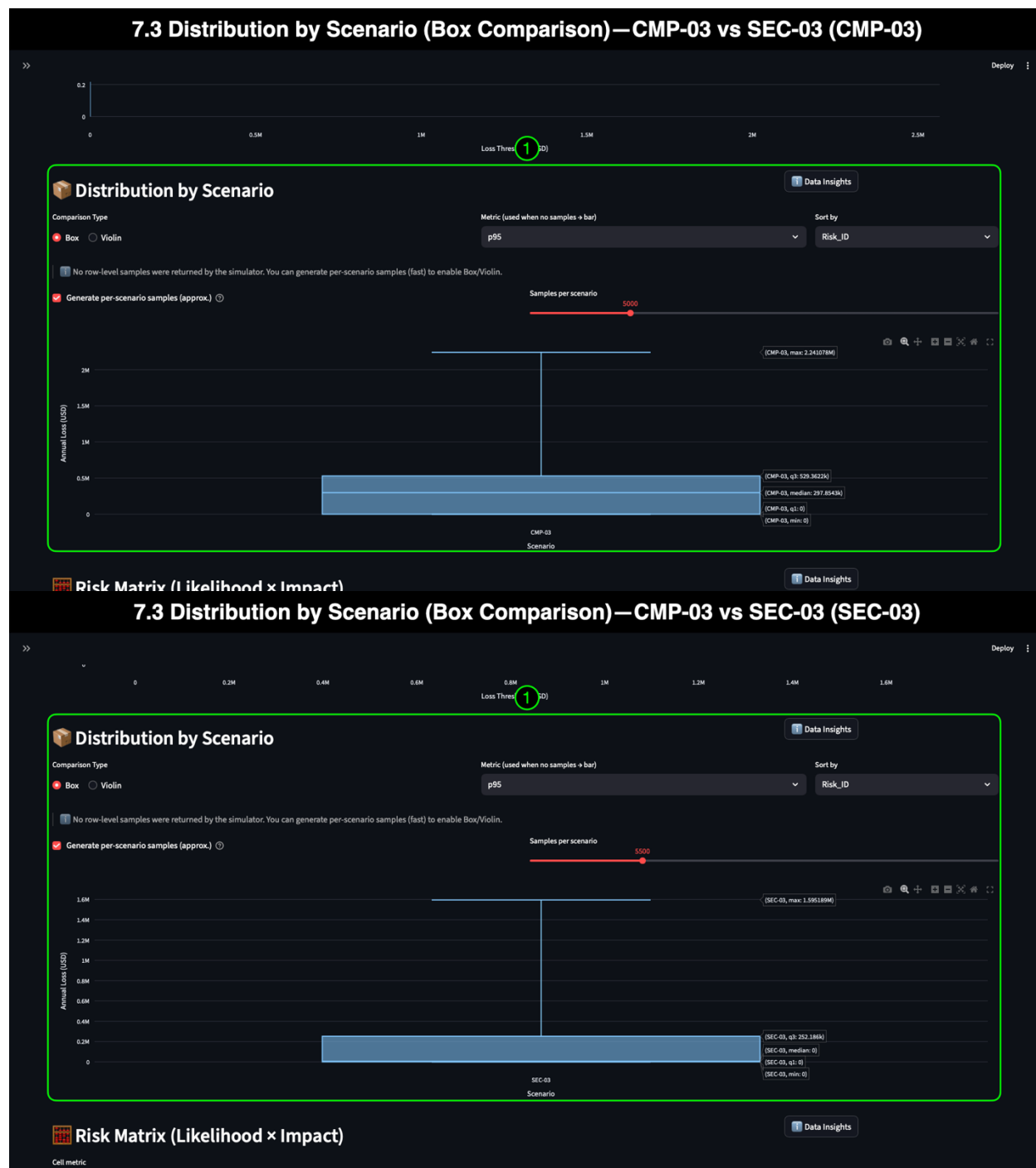
- **Predictable and frequent** (CMP-03)
- **Volatile and opportunistic** (SEC-03)

This contrast prepares the audience for the deeper quartile and density comparisons in the next section.

## 7.3 Distribution by Scenario (Box Comparison) — CMP-03 vs SEC-03

The **Box plot** comparison illustrates how losses are distributed across each scenario, providing a clear, quartile-based view. This visualization facilitates easy comparison of the **spread**, **central tendency**, and **volatility** of CMP-03 and SEC-03, eliminating the need for statistical expertise. For executives, GRC teams, finance professionals, and cybersecurity

practitioners, the Box Plot is often the fastest way to see where typical outcomes cluster—and where risk accelerates into the tail.





### 7.3.1 Annotation 1: Analysis — CMP-03 vs. SEC-03 (Box Mode)

#### Interpretation

##### **CMP-03 (SaaS CRM Vendor Breach)**

CMP-03's box plot shows:

- **Minimum:** \$0
- **q1:** Low \$200Ks
- **Median:** ~\$300K
- **q3:** ~\$450K–\$500K
- **Maximum:** ~\$1.5M

CMP-03 produces **moderate, tightly clustered losses**, reflecting predictable breach-response processes and regulated-data exposures.

##### **SEC-03 (Third-Party API Key Leakage)**

SEC-03's box plot shows:

- **Minimum:** \$0
- **q1:** \$0
- **Median:** \$0
- **q3:** Low-mid \$200Ks
- **Maximum:** ~\$1.7M

This structure reflects a **skewed, low-frequency distribution**, where many years incur no financial loss at all. Still, the years that do experience loss can have a significant impact.

##### **Key visual difference:**

- CMP-03 has a *solid central box* = predictable annualized exposure
- SEC-03 has a *compressed box dominated by zeros* = infrequent but potentially severe events

Both scenarios share a long tail, but CMP-03's tail is steadier while SEC-03's is more abrupt once losses occur.

### Audience-Focused Insights

#### Executives & Leadership

- CMP-03 represents a **recurring, budgetable** vendor risk.
- SEC-03 requires **contingency planning**, not simple annual budgeting—losses cluster at zero until they spike.

#### Finance, Insurance & Actuarial Stakeholders

- CMP-03's quartiles support pricing for **risk reserves, insurance retention levels**, and annual cost forecasting.
- SEC-03's structure emphasizes the need for **insurance coverage** and **incident response readiness**, given its volatile and rare-loss profile.

#### GRC & Audit

- CMP-03's quartile boundaries correlate well with qualitative “High Impact” ratings and GLBA safeguarding expectations.

- SEC-03's unpredictable quartile structure reveals why API and credential misuse events are harder to track and regulate, often requiring enhanced vendor SLAs.

### Cybersecurity & IT

- CMP-03: Focus on data governance, CRM vendor assurance, encryption enforcement, and DLP.
- SEC-03: Emphasize secrets scanning, key rotation, privilege minimization, and third-party repository oversight.

### Scenario Context Tie-In

This comparison echoes patterns seen in industry reports:

- **CMP-03's tight quartiles** align with the consistent financial consequences of regulated data exposure [2][3].
- **SEC-03's zero-dominated quartiles** reflect the low-frequency, high-severity nature of credential abuse documented in the Verizon DBIR and ENISA threat landscape [1][4].

CMP-03 is the “steady” vendor risk material every year.

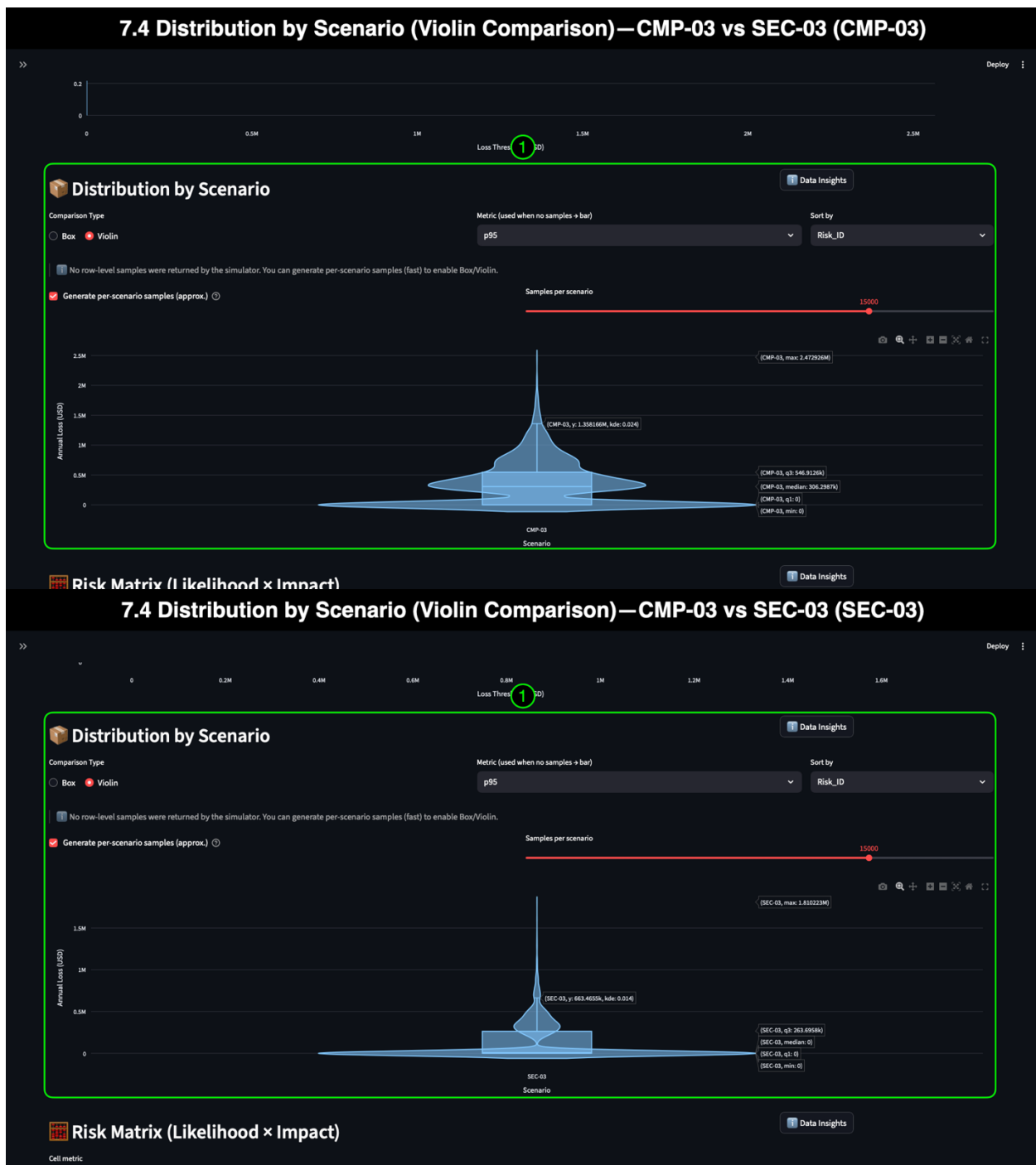
SEC-03 is the “spiky” vendor risk—quiet until the year it's not.

These differences set up an even more vivid comparison in the next section (7.4), where the Violin Plot reveals the density and shape behind these quartile structures.

## 7.4 Distribution by Scenario (Violin Comparison) — CMP-03 vs SEC-03

The **Violin Plot** provides the most profound insight into the loss distribution of each scenario. Where the Box Plot presents quartiles, the Violin Plot shows **how often** simulated losses occur across different ranges. This view is especially valuable when comparing scenarios with very different statistical signatures, such as CMP-03's predictable mid-range losses and SEC-03's volatile, zero-heavy pattern.

The Violin Plot helps all audience groups—executives, finance, GRC, audit, cybersecurity—understand not just the *size* of losses, but the *likelihood and density* of each loss range.



#### 7.4.1 Annotation 1: Analysis — CMP-03 vs SEC-03 (Violin Mode)

##### Interpretation

##### CMP-03 (SaaS CRM Vendor Breach)

The CMP-03 violin has:

- A pronounced bulge between **\$200K–\$500K**

- A consistent narrowing above ~\$500K
- A long, but thin tail up to ~\$1.5M
- A compact, stable shape that mirrors its steady histogram

This density curve signifies a **predictable, moderate annual impact**, with well-defined mid-range clusters typical of regulated PII exposures.

### SEC-03 (Third-Party API Key Leakage)

The SEC-03 Violin has:

- A vast, dense bulge at **\$0**, reflecting many zero-loss years
- A sharp, narrow rise starting in the low six figures
- A far thinner mid-range density than CMP-03
- A longer, thinner tail extending to ~\$1.7M

SEC-03 exhibits a **high-volatility, rare-loss pattern**, with minimal losses in most years and severe spikes when attackers exploit leaked API credentials.

## Audience-Focused Insights

### *Executives & Leadership*

- CMP-03's Violin confirms a "**predictable, regulated risk**"—financially material every year.
- SEC-03 exhibits a "**quiet until catastrophic**" pattern, making it ideal for discussions around insurance, emergency funding, and cyber resilience planning.

### *Finance & Actuarial Stakeholders*

- CMP-03: Supports multi-year forecasting, reserve planning, and retention threshold modeling.
- SEC-03: Shows instability that makes financial forecasting difficult; requires **tail management**, not predictable budgeting.

### *GRC, Legal & Audit*

- CMP-03 density aligns well with GLBA-driven safeguards, making it easier to justify vendor assessments and rigorous due diligence.
- SEC-03's shape highlights compliance blind spots in **vendor pipelines, key rotation**, and **access governance**, reinforcing the need for enhanced oversight.

### *Cybersecurity & IT*

- CMP-03: Density confirms that controls reducing data exposure return consistent values.
- SEC-03: Sharp density cliffs reveal where controls around **least privilege, secrets scanning**, and **API monitoring** provide disproportionate impact.

## Scenario Context Tie-In

The Violin comparison exposes a fundamental difference between the two scenarios:

- **CMP-03 represents a vendor-side data exposure risk that is steady, frequent, and aligned with documented breach cost ranges** in mid-market SaaS implementations [2][3].
- **SEC-03 represents an identity/API misuse risk that is irregular but potentially severe**, echoing the findings from Verizon’s DBIR and ENISA, which indicate that stolen credentials and misconfigured APIs are among the top modern attack vectors [1][4].

The Violin Plot makes this contrast unmistakable:

- CMP-03 = *predictable risk*
- SEC-03 = *volatile, spike-driven risk*

This comparison sets the stage for the final visualization—the **Risk Matrix**—which combines qualitative ratings with quantitative outputs to illustrate how these scenarios differ in practice.

## 7.5 Risk Matrix — CMP-03 vs SEC-03

The **Risk Matrix** comparison provides a unified view of the entire analysis by combining qualitative ratings from the risk register with quantitative outcomes from the Monte Carlo simulation. The Risk Matrix shows how traditional red/yellow/green scoring aligns—or diverges—from measurable financial impact.

Unlike the histogram, CDF, or density plots, the Risk Matrix is immediately familiar to executives, auditors, and compliance teams. Its strength lies in showing whether the organization’s *subjective assessments* accurately reflect the *quantifiable reality* of each scenario.



## 7.5.1 Annotation 1: Qualitative vs Quantitative Alignment — CMP-03 vs SEC-03

### Interpretation

#### CMP-03 (SaaS CRM Vendor Breach)

Qualitative Rating:

**RiskQuant v1.0 — Developed by Bryon Mascher · © 2025 All Rights Reserved ·**  
[linkedin.com/in/bryonmaschercybersec](https://linkedin.com/in/bryonmaschercybersec) · [github.com/DigiFenix777](https://github.com/DigiFenix777)

- **Likelihood:** Medium
- **Impact:** High
- **Risk Rating:** High

Quantitative Outcomes:

- **EAL:** ~\$350K
- **Median:** ~\$305K
- **p95:** ~\$1.05M
- **Max Observed:** ~\$2.56M

CMP-03 sits firmly in the **High Impact / Medium–High Probability** quadrant.

The qualitative score aligns well with the quantitative profile—moderate but consistently material losses and regulated-data exposure that elevate both cost and frequency.

### **SEC-03 (Third-Party API Key Leakage)**

Qualitative Rating:

- **Likelihood:** Low
- **Impact:** High
- **Risk Rating:** High

Quantitative Outcomes:

- **EAL:** ~\$120K
- **Median:** \$0
- **p95:** ~\$537K
- **Max Observed:** ~\$1.71M

SEC-03 falls into **Low Likelihood / High Impact**—exactly the quadrant associated with infrequent but disruptive identity- and API-misuse incidents. The qualitative rating captures the rarity of exploitation but cannot express the *financial volatility*, which is where the simulation provides clarity.

## Audience-Focused Insights

### *Executives & Leadership*

- CMP-03's placement validates that regulated data exposure produces predictable, high-cost outcomes that justify investment in vendor oversight and breach-prevention controls.
- SEC-03's position highlights a class of risk that is easy to underestimate: events that are rare yet capable of producing severe, unbudgeted impact.

### *Finance & Actuarial Teams*

- CMP-03 fits well into annual forecasting and insurance planning.
- SEC-03 requires different levers—higher variance means coverage limits, deductibles, and retention thresholds need careful review.

### *GRC & Audit*

- CMP-03 strongly supports GLBA and vendor safeguarding documentation.

- SEC-03 highlights compliance challenges related to secrets management, identity governance, and third-party pipeline controls.

### *Cybersecurity & IT*

- CMP-03 reinforces controls around DLP, vendor monitoring, and CRM access governance.
- SEC-03 highlights gaps around key rotation policies, automated secrets scanning, and access boundary hardening.

### Scenario Context Tie-In

The Risk Matrix comparison drives home the fundamental reality of these two vendor-origin risks:

- **CMP-03** is correctly rated as High and quantitatively demonstrates its consistency and financial materiality, aligning with mid-market regulated data breach patterns [2][3].
- **SEC-03** is also rated High, but for different reasons—it carries a lower frequency yet severe tail potential, consistent with the rising impact of API and credential misuse incidents reported by DBIR and ENISA [1][4].

Together, they illustrate why mid-market organizations struggle with vendor risk:

- **Some risks are steady and predictable** (CMP-03)
- **Some risks explode unpredictably** (SEC-03)
- Both can be financially and operationally significant

The analysis culminates in **Section 8: Takeaways**, which translates these findings into concrete recommendations.



## 8. Conclusions & Scenario Takeaways

The comparative analysis of **CMP-03 (SaaS CRM Vendor Breach)** and **SEC-03 (Third-Party API Key Leakage)** demonstrates how different forms of vendor-origin risk behave in mid-market environments—and why both require dedicated, evidence-based management. RiskQuant’s simulation outputs reveal that while these scenarios share a high qualitative risk rating, their **quantitative characteristics, predictability, and financial profiles differ significantly**, shaping how organizations must prioritize controls, budget, and governance efforts.

Industry reports affirm these patterns:

- **Vendor and supply-chain compromises account for ~41% of breaches** [1].
- **API abuse and credential misuse** continue to rise as top attack vectors [1][4].
- **SaaS/CRM PII exposures** routinely exceed \$1M in cost for mid-market firms [2][3].
- Supply-chain incidents remain **13–20% more expensive** than internal-origin breaches [2].

These external findings align closely with the simulation behavior observed in RiskQuant, validating the realism and value of the model.

### 8.1 CMP-03 Key Takeaways — Predictable, High-Impact Vendor Breach

CMP-03’s behavior across all visualizations (KRIs, histogram, CDF, box/violin plots, and the risk matrix) points to a scenario that is:

- **Moderate- to high-impact**
- **Frequent and predictable**
- **Financially material every year**
- **Driven by regulated customer data exposure (GLBA)**
- **Stable across quartiles with limited volatility**

*What this means for the organization*

- CMP-03 requires **ongoing annual investment**, not episodic reaction.
- Controls around **vendor assurance, data masking, CRM access governance, encryption validation**, and **DLP** have high, repeatable ROI.
- GLBA-driven reporting and safeguarding reviews can be supported directly with RiskQuant outputs.
- Finance and leadership can reliably integrate CMP-03 into long-term planning due to its stability and reliability.

### 8.2 SEC-03 Key Takeaways — Volatile, Low-Frequency but Severe Exposure

SEC-03’s loss signature is dramatically different:

- **Low-frequency, high-severity**
- **Median = \$0, but a substantial p95 tail**
- **Losses spike sharply once API or credential misuse occurs**
- **Volatile and more complex to forecast**
- **Aligned with modern cloud and API attack patterns (DBIR, ENISA)**

#### *What this means for the organization*

- SEC-03 is a **resilience problem**, not a budgeting problem.
- Controls such as secret **scanning**, **key rotation**, **RBAC hardening**, **privileged identity management**, **API rate limiting**, and **third-party repository audits** significantly reduce tail risk.
- Leadership should consider **cyber insurance**, **incident retainer contracts**, and **resilience budgeting** due to volatility.
- SEC-03 visualizations highlight why “rare” cannot be equated with “safe.”

## 8.3 What the Comparison Reveals

When the two scenarios are compared side-by-side:

### **CMP-03 = Predictable, recurring annual exposure**

- Easy to model
- Statistically stable
- Consistently material
- Strongly tied to regulated data

### **SEC-03 = Unpredictable, spiky exposure**

- Harder to predict
- Zero-loss years dominate
- Tail events remain severe
- Driven by credential/API vulnerabilities

This comparison reveals a core mid-market vendor risk: organizations face *both* steady-state breaches and unpredictable identity-based disruptions. Understanding this distinction allows leadership and technical teams to prioritize controls, align budgets, and shape risk appetite statements.

## 8.4 Recommendations for Leadership & Stakeholders

### *Executives (CEO, COO, CFO)*

- Treat CMP-03 as a **known liability** requiring recurring investment.
- Treat SEC-03 as a **resilience exposure** requiring contingency funding.
- Align cyber insurance retention/deductibles to CMP-03 p95 values (~\$1M).
- Protect cash flow against SEC-03 volatility through appropriate coverage.

### *CISO / Security Engineering*

- Strengthen vendor due diligence, CRM access governance, and SaaS data safeguards (CMP-03).
- Implement automated key/credential protection frameworks (SEC-03).
- Expand secrets scanning in CI/CD pipelines and third-party repos.
- Enforce least privilege across cloud IAM and vendor integrations.

### *GRC, Legal & Compliance*

- Use CMP-03 simulation outputs to support **GLBA Safeguards Rule** documentation.
- Tighten vendor contracts to include:
  - API key rotation
  - Mandatory secrets scanning
  - Role review requirements
  - Incident transparency clauses
- Use quantitative outputs in board reporting and risk appetite updates.

### *Finance, Budget, & Insurance*

- Use CMP-03 as the basis for annual cyber reserve planning.
- Model SEC-03 as a high-volatility risk requiring additional insurance attention.
- Use EAL, p90, and p95 outputs to negotiate premiums and retention levels.

## 8.5 How RiskQuant Enables Better Decisions

RiskQuant's Monte Carlo simulation capabilities transform traditional, ambiguous qualitative ratings into **financially meaningful outputs**, enabling:

- Better budgeting
- Clearer risk prioritization
- Cross-team alignment
- Faster board and audit communication
- Evidence-based policy and vendor decisions
- More predictable and defensible cyber insurance positioning

The CMP-03 vs SEC-03 comparison illustrates how two “High” risks are **not equal**—and how quantitative analysis reveals the difference.

## 8.6 Explore the Complete RiskQuant Scenario Series

This Mid-Market demo is part of a three-scenario series designed to help organizations of different maturity levels understand how RiskQuant quantifies cyber risk, transforms qualitative ratings into financial insight, and supports decision-making across leadership, GRC, finance, and cybersecurity teams. Each demonstration focuses on realistic risks **that industry research** documents well and **that commonly affect organizations of that size**. Together, these demos show how RiskQuant scales from small businesses to global

enterprises—illuminating where risk originates, how it behaves, and what leaders can do about it.

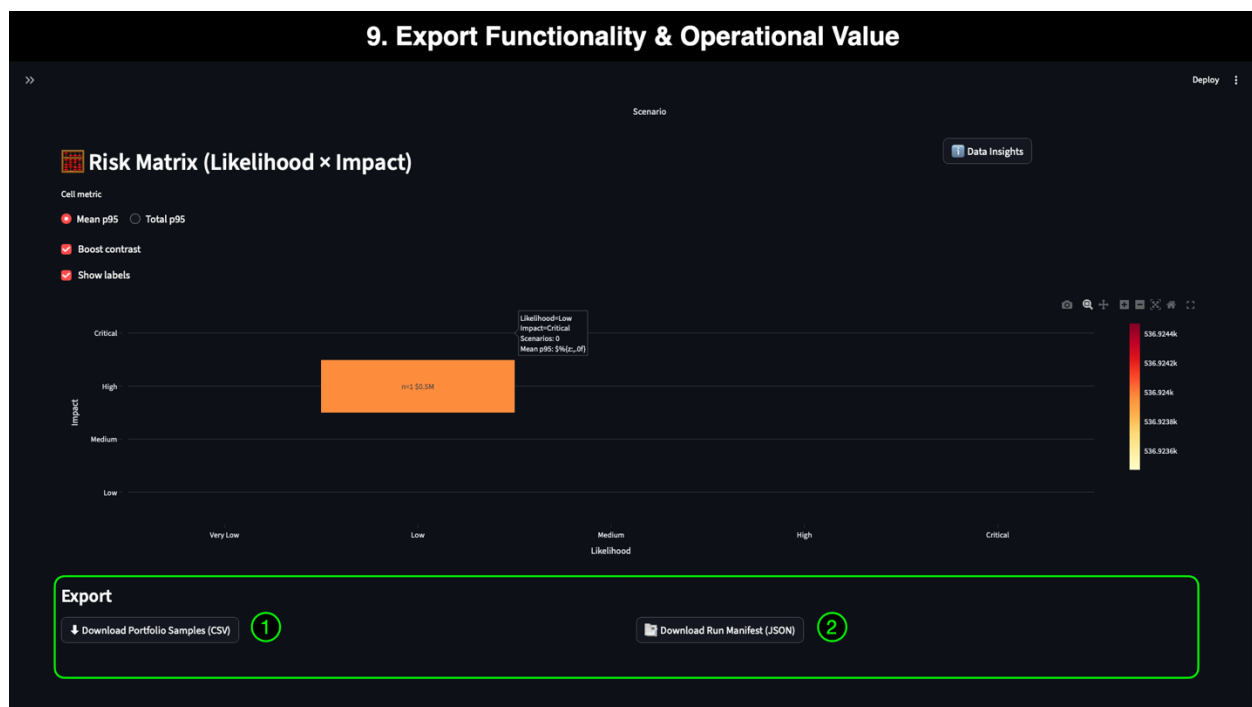
## RiskQuant Demo Series

- **SMB Scenario: Phishing and Credential Compromise → SMB Operational Exposure**
  - Small and growing organizations face constant phishing pressure and lack the staffing depth to absorb identity-related incidents. This demo highlights how common credential theft translates into financial loss and showcases how Monte Carlo simulation supports tactical prioritization and cyber hygiene investments.
- **Mid-Market Scenario: Vendor Supply-Chain Compromise → Business Disruption**  
*(this demo)*
  - Mid-sized organizations face a dual risk profile: predictable, regulated data breaches and volatile, API- or credential-driven incidents involving vendors. This demo quantifies both patterns and shows how RiskQuant helps executives and technical teams evaluate supply-chain exposures, vendor oversight, and identity governance.
- **Enterprise Scenario: Global SaaS Platform Outage & Data Breach → Enterprise Portfolio Shock**
  - Large enterprises rely on complex multi-vendor ecosystems, cloud IAM, global data flows, and cross-border compliance. This demo models a high-impact SaaS provider failure to show how RiskQuant helps CISOs, CIOs, and risk committees understand systemic risk propagation, regional impacts, and cross-domain dependencies.

## 9: Export Functionality & Operational Value

Exporting simulation outputs is a core part of the RiskQuant workflow and a significant contributor to its usefulness across Mid-Market organizations. While the dashboard provides fast visual insight, exported data supports **collaboration, audit readiness, reproducibility, and downstream analysis**, enabling teams to use RiskQuant in real-world operational settings.

Whether preparing for a board meeting, conducting a GLBA Safeguards review, negotiating cyber insurance, or coordinating with third-party assessors, exportable data ensures that findings are **defensible, portable, and easily integrated** into existing processes.



### 9.1 How Export Functionality Benefits Each Audience Segment

#### *Executives & Leadership*

- Simplifies the incorporation of quantitative risk metrics into board presentations.
- Provides evidence-based loss estimates for budget planning, capital allocation, and cyber insurance strategy.

#### *Finance, Accounting & Actuarial Teams*

- Enables deeper analysis of expected loss distributions, tail risk, and year-over-year trends.
- Supports renewal negotiations and reserve modeling with carriers or financial partners.

### *GRC, Legal & Audit*

- Provides exportable artifacts for GLBA Safeguards Rule assessments, SOC 2 reviews, PCI DSS scoping, and vendor due diligence.
- Ensures auditability and traceability of inputs, configuration, and scenario definitions.

### *Cybersecurity & Engineering*

- Supports technical tabletop exercises, incident simulations, and operational risk reviews.
- Aligns simulation parameters with identity, access, and vendor management workflows.

### *External Partners (vCISO, Consultants, Assessors)*

- Ensures consistent reproduction of client simulations for compliance, reporting, and control development.
- Simplifies collaboration across organizational and vendor boundaries.

## 9.1.1 Annotation 1: Download Portfolio Samples (CSV)

The CSV export provides a complete dataset of the simulated annual loss samples for the selected scenario(s). These samples allow teams to:

- Perform independent statistical analysis.
- Build custom dashboards (Power BI, Tableau, Excel).
- Compare simulated outcomes against historical incident data.
- Provide evidence for cyber insurance underwriting or renewal reviews.
- Validate or supplement internal financial modeling and risk quantification practices.

This export eliminates friction by providing every stakeholder with the ability to work with *raw, structured data*, rather than relying on screenshots or interpreted values.

### *Export Format Description*

A standard CSV file containing one row per sample, typically including:

- Scenario
- Sample\_ID
- Annual\_Loss\_USD

This structure ensures compatibility with nearly all analytics, BI, and risk modeling tools used throughout Mid-Market organizations.

## 9.1.2 Annotation 2: Download Run Manifest (JSON)

The Run Manifest export provides a structured, machine-readable record of the simulation configuration, including:

- Selected scenarios
- Number of simulations

- Loss distributions
- Random seed
- Percentiles displayed
- Risk register source
- Simulation metadata and timestamps

This artifact is essential for **audit trails, reproducibility, and documentation**.

It enables:

- Transparent governance aligned with GLBA and SOC 2 model validation expectations.
- Repeatable quarterly or annual risk reporting.
- Collaboration with auditors, regulators, or external assessors.
- Consistency across cross-functional review cycles and vendor management workflows.

### *Export Format Description*

A JSON file containing structured key-value pairs, typically including:

- `risk_register_path`
- `simulation_parameters`
- `selected_scenarios`
- `percentiles`
- `random_seed`
- `run_timestamp`

JSON ensures long-term stability, cross-platform compatibility, and ease of integration into GRC platforms, documentation repositories, or automated reporting processes.

## 7. Author's Note

This mid-market quantitative risk demonstration represents a culmination of my ongoing transition from a decade in technical marketing, product storytelling, and solution consulting into a cybersecurity career focused on **Governance, Risk & Compliance (GRC)** and **quantitative risk analysis**. Over the past several years, I have dedicated myself to developing the skills, mindset, and technical expertise required to support organizations facing increasingly complex regulatory, operational, and cyber risk challenges. My background in building high-fidelity product simulations, crafting clear technical narratives, and enabling decision-makers strongly shaped the structure of this work. I approached each scenario—as well as the design of RiskQuant itself—with the same principles I relied on when creating enterprise demos for Microsoft and other global technology organizations: clarity, accuracy, purposeful storytelling, and a deep empathy for the professionals who must translate risk into action.

This document also reflects the knowledge and discipline I gained through my **B.S. and M.S. in Cybersecurity and Information Assurance at Western Governors University**, along with the frameworks I studied while pursuing certifications such as SecurityX, Security+, CySA+, PenTest+, Project+, SSCP, CCSP, CISSP, and CISM. These academic and professional experiences informed how I structured risk registers, modeled likelihood and impact, justified loss parameters, and aligned scenarios with frameworks such as **HIPAA, HITECH, NIST CSF, NIST SP 800-30, SP 800-53**, and industry breach data. RiskQuant itself demonstrates the intersection of several capabilities I bring to a GRC or risk-focused role:

- **Python development** and the ability to translate risk frameworks into quantitative models
- **AI-assisted application design** that accelerates innovation and improves clarity
- **Data visualization and dashboard UX** rooted in enterprise-grade presentation standards
- **Regulatory reasoning** that maps simulation outputs to compliance and audit narratives
- **Technical communication** that bridges executives, engineers, clinicians, and legal teams
- **Risk storytelling** that makes complex concepts intelligible, defensible, and actionable

My purpose in creating this enterprise healthcare demonstration is twofold:

- **To show how quantitative methods—such as Monte Carlo simulation—can transform the way organizations evaluate cybersecurity and operational risk.**
- **To demonstrate the skills, judgment, and analytical approach I would bring to a GRC, risk management, or cybersecurity strategy team.**

The four scenarios in this document reflect real pressures faced by health systems: PHI exposure pathways, identity compromise, vendor ecosystem risks, and catastrophic

**RiskQuant v1.0 — Developed by Bryon Mascher** · © 2025 All Rights Reserved ·  
[linkedin.com/in/bryonmaschercybersec](https://linkedin.com/in/bryonmaschercybersec) · [github.com/DigiFenix777](https://github.com/DigiFenix777)



downtime. My goal was to present these issues with the depth and professionalism they deserve—grounded in data, enriched with regulatory context, and delivered in a format accessible to executives, cybersecurity practitioners, auditors, compliance officers, and operational leaders.

Ultimately, this project is not just a demo.

It is a representation of how I work:

**Analytically, collaboratively, creatively, and with an uncompromising focus on clarity and measurable impact.**

I view RiskQuant as both an educational artifact and a demonstration of capability—evidence that curiosity, discipline, and thoughtful use of AI can transform a complex idea into a rigorous, enterprise-caliber product. My goal is to bring that same mindset, drive, and craftsmanship to the organizations I support in my cybersecurity career.

—Bryon Mascher

Cybersecurity • GRC • Risk Analysis • Data Visualization

 [linkedin.com/in/bryonmaschercybersec](https://www.linkedin.com/in/bryonmaschercybersec)

 [github.com/DigiFenix777](https://github.com/DigiFenix777)

## 8. Sources

**[1]** Verizon Business. *2024 Data Breach Investigations Report (DBIR)*.

Industry-leading annual analysis of breach patterns, attack vectors, and threat frequency, widely used for contextualizing phishing and credential-compromise trends.

**[2]** IBM Security. *2024 Cost of a Data Breach Report*.

Provides empirical cost data for typical and severe breach outcomes, informing comparisons to expected annual loss (EAL), median, and tail-risk values.

**[3]** Datto. *2023 Global State of SMB Cybersecurity Report*.

Describes SMB-specific threat patterns, resource limitations, and the prevalence of phishing, ransomware, and credential-driven intrusions.

**[4]** ENISA. *2024 Threat Landscape Report*.

Analyzes evolving attacker behaviors, multi-vector campaigns, and modern exploitation trends across global sectors.

**[5]** NIST SP 800-53 Rev. 5. *Security and Privacy Controls for Information Systems and Organizations*.

Defines qualitative likelihood/impact assessments, as well as governance controls, referenced in the qualitative-to-quantitative mapping.

**[6]** NIST SP 800-37 Rev. 2. *Risk Management Framework (RMF): A System Life Cycle Approach for Security and Privacy*.

Provides risk management concepts used to relate simulation outcomes to risk tolerance, monitoring, and treatment plans.

**[7]** ISO/IEC 27005:2018. *Information security risk management*.

Establishes international standards for risk identification, qualitative scoring, and scenario-based analysis aligned with the qualitative risk matrix.